FICTIONAL PROTOTYPE. Staged review answers from a fictional organisation. All figures are test fixtures, not an approved score.

MK FRAUD INSIGHTS

COMPREHENSIVE FRAUD READINESS REPORT

Fraud exposure, target control environment and implementation programme

87.80
READINESS / 100

STRATEGIC
MATURITY BAND

PREPARED FOR

Fictional Retail Group (overstated confirmations)

Assessment reference · FX-P6b

CONFIDENTIAL · AUTOMATED ANALYSIS · NOT INDEPENDENTLY REVIEWED

FICTIONAL PROTOTYPE. Staged review answers from a fictional organisation. All figures are test fixtures, not an approved score.

Contents

Management report — SECTIONS 1–9

1 · Where the organisation stands

2 · What is driving the position

3 · Where the material fraud exposure sits

4 · Fraud scenario portfolio

5 · The control environment management should build

6 · Who must own the response

7 · Decisions leadership must make

8 · What should happen, and in what order

9 · How management will know it is working

Analytical registers — APPENDICES A–F

A · Finding register — 25 entries

B · Fraud risk register — 25 entries

C · Control blueprint register — 25 entries

D · Evidence requirement register — 13 entries

E · 12-month action and assurance register — 59 entries

F · Measurement register — 25 entries

THE TWO HALVES OF THIS REPORT

Sections 1–9 are the management report: what the assessment shows, what it means, and what to do about it. Appendices A–F are the analytical registers behind those sections. They contain every finding, risk, control design, evidence requirement, action and measure, with the identifiers that connect them. The management sections state nothing the registers do not hold.

BASIS OF THIS REPORT

This report is produced by automated analysis of the recorded MK Fraud Readiness assessment. It has not been independently reviewed. No evidence has been examined, no control has been tested for operating effectiveness, no personnel have been interviewed, and no assurance opinion is given. Assessment positions are self-reported by the organisation. Recommended control designs, evidence requirements and operating measures are MK methodology: what good practice requires, not observations of what the organisation currently does.

FICTIONAL PROTOTYPE. Staged review answers from a fictional organisation. All figures are test fixtures, not an approved score.

The assessed readiness position

87.80	Strategic	10	25	25
READINESS SCORE OUT OF 100	MATURITY BAND	DOMAINS ASSESSED	MATERIAL FINDINGS	CONTROL DESIGNS RECOMMENDED

Domain readiness profile

Fraud governance and accountability	90.00	Strategic
Fraud risk assessment	91.70	Strategic
Ethics, integrity and anti-corruption	81.00	Strategic
Third parties and supply chain	85.70	Strategic
People, payroll and insider risk	89.10	Strategic
Finance, banking and financial reporting	92.50	Strategic
Customers, revenue and products	92.00	Strategic
Assets, cash and inventory	82.00	Strategic
Digital, cyber-enabled and identity fraud	87.10	Strategic
Detection, speak-up and response	86.70	Strategic

Ordered as assessed. Positions are self-reported through the assessment and have not been independently verified.

EXECUTIVE INTERPRETATION

Management interpretation is added at generation. The analysis on this page stands without it.

FICTIONAL PROTOTYPE. Staged review answers from a fictional organisation. All figures are test fixtures, not an approved score.

The patterns beneath the score

The assessment produced 25 material findings. They resolve into 9 connected patterns, ordered by how much of the organisation's critical control population each one affects.

PATTERN	FINDINGS	CRITICAL	HARD GATE	MANAGEMENT QUESTION THIS RAISES
Supplier and payment integrity Third parties and supply chain · Ethics, integrity and anti-corruption · Finance, banking and financial reporting	7	4	Not recorded	Can value be redirected before anyone independently challenges it?
Fraud governance and risk identification Fraud risk assessment · Fraud governance and accountability	5	3	Not recorded	Does anyone own fraud risk, and do we know where it sits?
Payroll integrity People, payroll and insider risk	3	2	Not recorded	Could pay be redirected, inflated or paid to someone who does not work here?
Incident response and evidence integrity Detection, speak-up and response	3	2	Not recorded	When something is suspected, can we contain it and keep the evidence?
Identity and access challenge People, payroll and insider risk · Digital, cyber-enabled and identity fraud	2	1	Not recorded	Is authority verified at the points where it can be misused?
Stock and asset custody Assets, cash and inventory	2	1	Not recorded	Could stock or assets leave, or be written off, without a record that someone checks?
Cash custody Assets, cash and inventory	1	1	Not recorded	Could cash be taken before or after it is recorded without anyone noticing?
Detection and exception review Customers, revenue and products	1	1	Not recorded	Would unusual activity be seen and challenged in time?
Culture and continuous improvement Ethics, integrity and anti-corruption	1	Not recorded	Not recorded	Do people recognise fraud, and does the control environment learn?

Every finding behind these patterns is listed in Appendix A.

> **WHY THIS MATTERS**
>
> Management interpretation is added at generation. The analysis on this page stands without it.

FICTIONAL PROTOTYPE. Staged review answers from a fictional organisation. All figures are test fixtures, not an approved score.

Exposure by control family

25 fraud risks arise from the assessed position. They concentrate in 9 exposure families.

EXPOSURE FAMILY	RISKS	DOMAINS AFFECTED	WHAT THE ORGANISATION IS EXPOSED TO
Supplier and payment integrity	7	Ethics, integrity and anti-corruption · Third parties and supply chain	Can value be redirected before anyone independently challenges it?
Fraud governance and risk identification	5	Fraud governance and accountability · Fraud risk assessment	Does anyone own fraud risk, and do we know where it sits?
Payroll integrity	3	People, payroll and insider risk	Could pay be redirected, inflated or paid to someone who does not work here?
Incident response and evidence integrity	3	Detection, speak-up and response	When something is suspected, can we contain it and keep the evidence?
Identity and access challenge	2	People, payroll and insider risk · Digital, cyber-enabled and identity fraud	Is authority verified at the points where it can be misused?
Stock and asset custody	2	Assets, cash and inventory	Could stock or assets leave, or be written off, without a record that someone checks?
Culture and continuous improvement	1	Ethics, integrity and anti-corruption	Do people recognise fraud, and does the control environment learn?
Detection and exception review	1	Customers, revenue and products	Would unusual activity be seen and challenged in time?
Cash custody	1	Assets, cash and inventory	Could cash be taken before or after it is recorded without anyone noticing?

Full risk statements, causes and treatment directions are in Appendix B. Risks are derived from assessed control positions; no likelihood or monetary value is assigned, because the assessment does not support one.

MANAGEMENT IMPLICATION

Management interpretation is added at generation. The analysis on this page stands without it.

FICTIONAL PROTOTYPE. Staged review answers from a fictional organisation. All figures are test fixtures, not an approved score.

Fraud scenario portfolio

Conditional pathways derived from the recorded control position. Each shows how it could begin, how it could progress, the control response that would interrupt it, and what management could observe first. No allegation that any event has occurred.

PATHWAY	HOW IT COULD BEGIN	HOW IT COULD PROGRESS	INTERRUPTION POINT	WARNING INDICATORS	LINKS
A fictitious supplier is created and paid SUPPLIER PAYMENT DIVERSION	An insider or outsider adds a supplier that does not exist and invoices it.	Fictitious suppliers enter through onboarding that can be skipped. What the answers show: New supplier approved by another person: not in place. Directors compared with staff: not in place. Dormant suppliers deactivated: not in place.	New supplier approved by another person: the answer to "Does someone other than the person who captured a new supplier approve it before it becomes active?" is yes, across everything it should cover. Directors compared with staff: the answer to "Do you compare supplier directors, owners, addresses or bank accounts with your employee records?" is yes, across everything it should cover. Dormant suppliers deactivated: the answer to "Are suppliers that have not been used for a set period deactivated?" is yes, across everything it should cover. Suppliers re-checked: the answer to "Are existing suppliers re-checked periodically, not only when they are first added?" is yes, across everything it should cover. Directors and owners, including those behind holding companies, are identified for every new supplier from an independent source.	• Fictitious or shell suppliers • Undisclosed conflicts of interest • Misrepresented supplier credentials • Duplicate or false invoices	RISK-FS-D4-01, CI-FS-D4-01
Invoices are paid for goods or services not received or not agreed SUPPLIER PAYMENT DIVERSION	Overbilling, fictitious deliveries or inflated rates are paid.	Invoices paid without checking approval and receipt are how overbilling and fictitious deliveries get paid. What the answers show: Services confirmed: not in place. Most purchases are approved before commitment, through a purchase order or another record. Receipt is recorded for most deliveries, but not always before payment.	Services confirmed: the answer to "For services, does the person receiving the service confirm it was delivered before payment?" is yes, across everything it should cover. Every purchase is approved by someone with the authority to do so before the organisation commits, and the approval is recorded. Receipt is always recorded before the related invoice is paid.	• Unauthorised commitments and approval override • Duplicate or false invoices • Overpricing, overbilling and inflated variations • Goods or services paid for but not received • Counterfeit, substituted or substandard goods • Misrepresented supplier credentials	RISK-FS-D4-05, CI-FS-D4-05

PATHWAY	HOW IT COULD BEGIN	PROGRESS	INTERRUPTION POINT	INDICATORS	LINKS
Fraud risks are never identified DETECTION EVASION	Management does not know how fraud could happen in its own processes.	Whether risks are understood decides whether controls are aimed at the right schemes. What the answers show: Management has not seen or accepted the results. Process owners take part: not in place. Processes walked through: not in place.	Management formally accepts the results, and every significant risk has a named owner who has agreed to it. Process owners take part: the answer to "Do the people who run the processes take part, for example in workshops or interviews?" is yes, across everything it should cover. Processes walked through: the answer to "Does the assessment walk through each high-risk process step by step to find where fraud could happen?" is yes, across everything it should cover. Every risk is described as a specific scheme, with the perpetrator, the method and the process it affects.	• Fraud schemes that are never identified, so no control is designed to stop them • Effort and audit work not directed at the highest fraud risks • Controls that do not match how fraud actually happens • Blind spots in parts of the organisation or in types of fraud • An assessment that falls out of date as the business and threats change • Management override of controls not considered • Unable to show regulators, courts or funders that fraud risk was managed • Fraud committed for the organisation's benefit goes unrecognised • AI-enabled fraud not anticipated	RISK-FS-D2-01, CI-FS-D2-01
Staff do not know or understand what is expected THIRD PARTY COLLUSION	Expectations are not communicated in a way people understand, and nobody checks.	What the answers show: Written code of conduct: not in place. Programme independently reviewed: not in place. Trends reported upward: not in place.	Written code of conduct: the answer to "Does the organisation have a written code of conduct?" is yes, across everything it should cover. Programme independently reviewed: the answer to "Is the ethics and anti-bribery programme reviewed for whether it works, for example by internal audit or an independent reviewer?" is yes, across everything it should cover. Trends reported upward: the answer to "Are trends in declarations, gifts registers and ethics breaches reported to the board, council, social and ethics committee or owners?" is yes, across everything it should cover. Training on joining: the answer to "Do all employees receive fraud and ethics training when they join?" is yes, across everything it should cover.	• Unclear standards, so misconduct is excused as normal practice • Inconsistent consequences that signal the rules do not apply to everyone • Staff unable to recognise fraud, including AI-enabled schemes • Corporate criminal liability for bribery by people acting for the organisation	RISK-FS-D3-10, CI-FS-D3-10

PATHWAY	HOW IT COULD BEGIN	PROGRESS	INTERRUPTION POINT	INDICATORS	LINKS
Ghost employees are paid PAYROLL MANIPULATION	Fictitious or departed people stay on the payroll.	A payroll that nobody independent reviews before payment is where ghost employees hide. What the answers show: Payroll data analysed: set out but not yet working in practice. The person who captures the record checks it themselves. Independent review of payroll: only in some areas, cases or periods.	Payroll data analysed: the answer to "Does anyone analyse payroll data for unusual patterns?" is yes, across everything it should cover. Every new record is checked against a signed appointment by someone other than the person who captured it, before the first pay run. Independent review of payroll: the answer to "Has internal audit or an external reviewer examined payroll in the last two years?" is yes, across everything it should cover.	• Ghost or fictitious employees and payees • Unauthorised pay increases, allowances or deductions • Salary redirection through changed bank details • Manipulation of the payroll run or payment file • Payments to people after they leave • False or inflated expense claims	RISK-FS-D5-02, CI-FS-D5-02
An insider in a high-risk role works unchecked PRIVILEGED ACCESS MISUSE	Someone who never hands over work conceals an ongoing fraud.	What the answers show: Concerns raised fairly: not in place. Support for financial pressure: not in place. No conflicting duties when covering: set out but not yet working in practice.	Concerns raised fairly: the answer to "Is there a defined way for managers to raise and escalate concerns about an employee's behaviour, confidentially and without making accusations?" is yes, across everything it should cover. Support for financial pressure: the answer to "Does the organisation offer support to employees in financial difficulty, such as financial wellness or employee assistance programmes?" is yes, across everything it should cover. No conflicting duties when covering: the answer to "Are people in high-risk roles, such as those who can move money or change master data, kept from holding conflicting duties, even temporarily when they cover for colleagues?" is yes, across everything it should cover. A maintained list of high-risk roles covers the whole organisation, including roles that can move money, change master data or manage system access.	• Concealment by people who control a process alone • Misuse of privileged system access • False identity or credentials at hiring • Insider fraud that goes unnoticed despite visible warning signs • Payments to people after they leave	RISK-FS-D5-12, CI-FS-D5-12
Donations or sponsorships channel bribes THIRD PARTY COLLUSION	A payment to a cause linked to a decision-maker buys influence.	What the answers show: Recipients checked for links: only in some areas, cases or periods.	Recipients checked for links: the answer to "Are recipients checked for links to public officials, customers' decision-makers and employees before money is committed?" is yes, across everything it should cover.	• Donations and sponsorships used as disguised bribes • Undeclared conflicts of interest steering decisions • Corporate criminal liability for bribery by people acting for the organisation • Bribes paid or received to win or keep business	RISK-FS-D3-11, CI-FS-D3-11

PATHWAY	HOW IT COULD BEGIN	PROGRESS	INTERRUPTION POINT	INDICATORS	LINKS
Hours and overtime are inflated PAYROLL MANIPULATION	Unworked hours or overtime are approved and paid.	What the answers show: Hours approved by supervisor: only in some areas, cases or periods.	Hours approved by supervisor: the answer to "Are hours approved by a supervisor before they are paid?" is yes, across everything it should cover.	• Timesheet, overtime and leave abuse • Payments to people after they leave • Unauthorised pay increases, allowances or deductions	RISK-FS-D5-09, CI-FS-D5-09
AI-enabled schemes are not considered DETECTION EVASION	Deepfake instructions, synthetic identities and generated documents are missing from management's view of fraud risk.	These schemes defeat controls that rely on recognising a person or a document. What the answers show: Controls tested against AI fakes: not in place. AI methods tested per process: not in place. Own AI tools in scope: only in some areas, cases or periods.	Controls tested against AI fakes: the answer to "Are controls that rely on recognising a voice, face, signature or document assessed for whether an AI-generated fake could defeat them?" is yes, across everything it should cover. AI methods tested per process: the answer to "For each high-risk process, does the assessment ask how AI could be used against it, for example whether a cloned voice could pass a call-back check?" is yes, across everything it should cover. Own AI tools in scope: the answer to "Does it consider how the organisation's own AI tools, such as chatbots or automated approvals, could be manipulated or misused?" is yes, across everything it should cover. Simulated AI attack: the answer to "Has the organisation tested its verification controls with a simulated AI attack, such as a staged deepfake call to the finance team?" is yes, across everything it should cover.	• AI-enabled fraud not anticipated • Controls that do not match how fraud actually happens	RISK-FS-D2-02, CI-FS-D2-02
Cash takings are stolen CASH CUSTODY MISUSE	Takings are under-recorded or removed before banking.	Daily reconciliation of takings is the main control over cash theft. What the answers show: Cash is counted at some handovers, such as at the end of the day, but not at shift changes. Takings checked against an independent record: only in some areas, cases or periods. Deposits are checked against the statement occasionally.	Whenever cash changes hands, two people count it, record it and sign for it. Takings checked against an independent record: the answer to "Are takings reconciled to an independent record of activity, such as till rolls, ticket numbers, meter readings or occupancy, and not only to what the cashier records?" is yes, across everything it should cover. Every deposit and collection is reconciled to the bank statement by someone who does not handle the cash, using statements obtained directly from the bank.	• Theft of cash • Sales skimmed before they are recorded • Fake proof of payment, deposit or delivery	RISK-FS-D8-01, CI-FS-D8-01

PATHWAY	HOW IT COULD BEGIN	PROGRESS	INTERRUPTION POINT	INDICATORS	LINKS
Stock is stolen and hidden in the counts STOCK ASSET MISUSE	The people who hold stock also count it.	Counts done by the people who hold the stock can hide its theft. What the answers show: How stock is recorded: not in place. Store access limited: not in place. Issues against approved requests: not in place.	How stock is recorded: the answer to "How is stock recorded?" is yes, across everything it should cover. Store access limited: the answer to "Is access to stores and warehouses limited to authorised people, with visitors and contractors recorded?" is yes, across everything it should cover. Issues against approved requests: the answer to "Are stock issues and transfers recorded against an approved requisition or order before goods leave the store?" is yes, across everything it should cover. Differences explained before adjusting: the answer to "Are count differences investigated and explained before the records are adjusted?" is yes, across everything it should cover. High-value items secured: the answer to "Are high-value or easily resold items kept in a secure area with extra controls, such as cages, seals or serial number tracking?" is yes, across everything it should cover.	• Theft of stock and materials • False write-offs and adjustments that hide theft • Short deliveries and theft in transit • Organised theft of high-value materials • Fake proof of payment, deposit or delivery	RISK-FS-D8-02, CI-FS-D8-02
No one is answerable for fraud risk INCIDENT CONCEALMENT	Gaps persist because nobody owns fraud risk or has the authority to act.	Without a named, accountable person, other controls decay unnoticed. What the answers show: Owner has authority across the organisation: not in place. Dedicated fraud capability: only in some areas, cases or periods. Annual fraud action plan: only in some areas, cases or periods.	Owner has authority across the organisation: the answer to "Does the person who handles fraud risk have the authority and budget to act across the organisation, not only in their own area?" is yes, across everything it should cover. Dedicated fraud capability: the answer to "Is there a dedicated fraud risk or forensic function, or a defined external provider that fills that role?" is yes, across everything it should cover. Annual fraud action plan: the answer to "Is there an annual plan or budget for fraud risk work?" is yes, across everything it should cover. Qualified fraud leads: the answer to "Do the people who lead fraud risk work hold recognised training or qualifications, such as the CFE or forensic training?" is yes, across everything it should cover.	• No one accountable, so fraud risk goes unmanaged • Under-resourced or unqualified fraud capability • Management override of controls • Unclear expectations and inconsistent responses to fraud	RISK-FS-D1-01, CI-FS-D1-01

FICTIONAL PROTOTYPE. Staged review answers from a fictional organisation. All figures are test fixtures, not an approved score.

The control programmes

The 25 recommended control designs group into 9 programmes. Each is one coherent piece of work with one accountable executive.

PROGRAMME	CONTROLS	EVIDENCE	MEASURES	ACCOUNTABLE	HORIZON
Supplier and payment integrity	7	5	7	Head of procurement	30 days, 90 days
Fraud governance and risk identification	5	2	5	Risk function	30 days, 90 days
Payroll integrity	3	1	3	HR	30 days, 90 days
Incident response and evidence integrity	3	0	3	Head of forensics, risk	30 days, 90 days
Identity and access challenge	2	1	2	HR	90 days, 30 days
Stock and asset custody	2	1	2	Operations	30 days, 90 days
Culture and continuous improvement	1	0	1	People, learning and ethics	90 days
Detection and exception review	1	1	1	Commercial	30 days
Cash custody	1	2	1	Operations	30 days

Individual control designs are in Appendix C; the evidence each requires is in Appendix D.

> **CONTROL PROGRAMME SYNTHESIS**
>
> Management interpretation is added at generation. The analysis on this page stands without it.

FICTIONAL PROTOTYPE. Staged review answers from a fictional organisation. All figures are test fixtures, not an approved score.

Programme detail

Supplier and payment integrity

7 CONTROLS

Can value be redirected before anyone independently challenges it?

Accountable: Head of procurement
Delivery horizon: 30 days, 90 days
Evidence expected · 5 items across 4 controls
Effectiveness measures · 7

Controls: CI-FS-D3-01, CI-FS-D3-11, CI-FS-D4-01, CI-FS-D4-05, CI-FS-D4-12, CI-FS-D4-13, CI-FS-D6-01

Fraud governance and risk identification

5 CONTROLS

Does anyone own fraud risk, and do we know where it sits?

Accountable: Risk function
Delivery horizon: 30 days, 90 days
Evidence expected · 2 items across 1 controls
Effectiveness measures · 5

Controls: CI-FS-D1-01, CI-FS-D2-01, CI-FS-D2-02, CI-FS-D2-05, CI-FS-D2-06

Payroll integrity

3 CONTROLS

Could pay be redirected, inflated or paid to someone who does not work here?

Accountable: HR
Delivery horizon: 30 days, 90 days
Evidence expected · 1 items across 1 controls
Effectiveness measures · 3

Controls: CI-FS-D5-01, CI-FS-D5-02, CI-FS-D5-09

FICTIONAL PROTOTYPE. Staged review answers from a fictional organisation. All figures are test fixtures, not an approved score.

Programme detail

Incident response and evidence integrity

3 CONTROLS

When something is suspected, can we contain it and keep the evidence?

Accountable: Head of forensics, risk
Evidence expected · 0 items across 0 controls

Delivery horizon: 30 days, 90 days
Effectiveness measures · 3

Controls: CI-FS-D10-01, CI-FS-D10-02, CI-FS-D10-05

Identity and access challenge

2 CONTROLS

Is authority verified at the points where it can be misused?

Accountable: HR
Evidence expected · 1 items across 1 controls

Delivery horizon: 90 days, 30 days
Effectiveness measures · 2

Controls: CI-FS-D5-12, CI-FS-D9-01

Stock and asset custody

2 CONTROLS

Could stock or assets leave, or be written off, without a record that someone checks?

Accountable: Operations
Evidence expected · 1 items across 1 controls

Delivery horizon: 30 days, 90 days
Effectiveness measures · 2

Controls: CI-FS-D8-02, CI-FS-D8-11

FICTIONAL PROTOTYPE. Staged review answers from a fictional organisation. All figures are test fixtures, not an approved score.

Programme detail

Culture and continuous improvement

1 CONTROLS

Do people recognise fraud, and does the control environment learn?

Accountable: People, learning and ethics
Evidence expected · 0 items across 0 controls
Controls: CI-FS-D3-10

Delivery horizon: 90 days
Effectiveness measures · 1

Detection and exception review

1 CONTROLS

Would unusual activity be seen and challenged in time?

Accountable: Commercial
Evidence expected · 1 items across 1 controls
Controls: CI-FS-D7-01

Delivery horizon: 30 days
Effectiveness measures · 1

Cash custody

1 CONTROLS

Could cash be taken before or after it is recorded without anyone noticing?

Accountable: Operations
Evidence expected · 2 items across 1 controls
Controls: CI-FS-D8-01

Delivery horizon: 30 days
Effectiveness measures · 1

FICTIONAL PROTOTYPE. Staged review answers from a fictional organisation. All figures are test fixtures, not an approved score.

The governance model

Accountability is expressed as roles, not individuals. The assessment does not identify people, and this report does not infer them.

ROLE	STANDING	CONTROLS	DECISIONS	EVIDENCE	ESCALATION RESPONSIBILITY
Head of procurement	executive accountability	4	Not recorded	Not recorded	Not recorded
HR	executive accountability	4	Not recorded	Not recorded	Not recorded
Operations	executive accountability	3	Not recorded	Not recorded	Not recorded
Head of forensics, risk	executive accountability	3	Not recorded	Not recorded	Not recorded
Chief Executive / Managing Director	executive accountability	1	3	Not recorded	Not recorded
Chief Financial Officer	executive accountability	1	Not recorded	Not recorded	Not recorded
Commercial	executive accountability	1	Not recorded	Not recorded	Not recorded
Head of IT	executive accountability	1	Not recorded	Not recorded	Not recorded
Risk function	process ownership	4	2	2	Not recorded
People, learning and ethics	process ownership	4	Not recorded	Not recorded	Not recorded
Financial controller	process ownership	3	Not recorded	1	Not recorded
Procurement and vendor management	process ownership	2	Not recorded	2	Not recorded
Creditors manager	process ownership	2	Not recorded	Not recorded	Not recorded
Payroll manager	process ownership	2	Not recorded	1	Not recorded
HR manager	process ownership	2	Not recorded	1	Not recorded
HR lead	process ownership	1	Not recorded	Not recorded	Not recorded
CSI	process ownership	1	Not recorded	Not recorded	Not recorded
Customer service	process ownership	1	Not recorded	1	Not recorded
Store, branch	process ownership	1	Not recorded	2	Not recorded
Head of forensics	process ownership	1	Not recorded	Not recorded	Not recorded
Stores	process ownership	Not recorded	Not recorded	1	Not recorded
Warehouse	process ownership	Not recorded	Not recorded	1	Not recorded
Compliance	oversight	1	Not recorded	1	Not recorded
The board	oversight	Not recorded	Not recorded	Not recorded	Any suspected case of the scheme where no one is answerable for fraud risk, or any case processed without this control: owner has authority across the organisation.

FICTIONAL PROTOTYPE. Staged review answers from a fictional organisation. All figures are test fixtures, not an approved score.

The decision agenda

DECISION	WHY NOW	RECOMMENDED DIRECTION	OWNER	CONSEQUENCE OF DELAY
Name one accountable executive for each area with first-priority schemes open or unsupported: risk assessment (2), procurement and third parties (2), people and payroll (2), cash, stock and assets (2), detection and response (2), governance (1), ethics and anti-corruption (1), finance and banking (1), customers and revenue (1) and digital and identity (1).	Each scheme needs one person with authority over the process, the system and the people involved.	Risk manager or fraud risk lead for risk assessment, Head of procurement or CFO for procurement and third parties, HR or payroll manager for people and payroll and Operations or financial manager for cash, stock and assets.	Chief Executive / Managing Director 30 days	Schemes with no owner stay open, and the gaps that let them happen stay unassigned.
Approve the target design for risk assessment, where 2 first-priority schemes are open or unsupported.	The schemes share processes and owners; designing them together avoids separate partial fixes.	Management formally accepts the results, and every significant risk has a named owner who has agreed to it. Process owners take part: the answer to "Do the people who run the processes take part, for example in workshops or interviews?" is yes, across everything it should cover. Processes walked through: the answer to "Does the assessment walk through each high-risk process step by step to find where fraud could happen?" is yes, across everything it should cover. Every risk is described as a specific scheme, with the perpetrator, the method and the process it affects.	Risk function 60 days	Controls are added one at a time and the scheme stays open through the gaps between them.
Put first the controls that other controls depend on.	Building the dependent checks first produces controls that cannot run.	Sequence likelihood and impact rated, written code of conduct, directors compared with staff and dormant suppliers deactivated ahead of the checks that rely on them.	Risk function 30 days	Effort is spent on checks that cannot operate.
Decide whether to keep relying on 21 controls reported in place whose supporting practices were reported as gaps.	A self-reported control that its own practices do not support can give management comfort it has not earned.	Ask each process owner to confirm in writing how the control works without the missing practices, and close the practices in the next 60 days.	Chief Executive / Managing Director 30 days	The scheme is treated as covered when it may not be.
Have the board or its audit committee receive the status of the 15 first-priority schemes each month until they are closed.	Monthly reporting keeps the schemes visible to the people who can remove blockers.	A one-page scheme status: owner, controls in place, controls outstanding, next date.	Chief Executive / Managing Director 30 days	Progress is not visible until the next assessment.

A recommended direction is MK methodology. The decision remains management's.

FICTIONAL PROTOTYPE. Staged review answers from a fictional organisation. All figures are test fixtures, not an approved score.

The 12-month implementation programme

25 implementation actions, followed by 17 embed-and-evidence checkpoints, and 17 assure-and-review checkpoints across the 12-month programme. 59 programme objects in total, each with an owner, a deliverable and a test that shows it is complete.

HORIZON	WORK TYPE	COUNT	PROGRAMMES ADVANCED IN THIS HORIZON
30 days	Implement	15	Fraud governance and risk identification · Supplier and payment integrity · Payroll integrity · Detection and exception review · Cash custody · Stock and asset custody · Identity and access challenge · Incident response and evidence integrity
90 days	Implement	10	Fraud governance and risk identification · Culture and continuous improvement · Supplier and payment integrity · Payroll integrity · Identity and access challenge · Stock and asset custody · Incident response and evidence integrity
3-6 months	Embed & evidence	17	Fraud governance and risk identification · Supplier and payment integrity · Culture and continuous improvement · Payroll integrity · Identity and access challenge · Detection and exception review · Stock and asset custody · Incident response and evidence integrity
6-12 months	Assure & review	17	Fraud governance and risk identification · Supplier and payment integrity · Culture and continuous improvement · Payroll integrity · Identity and access challenge · Detection and exception review · Stock and asset custody · Incident response and evidence integrity

Every programme item, with its dependency and completion criterion, is in Appendix E.

IMPLEMENTATION SYNTHESIS

Management interpretation is added at generation. The analysis on this page stands without it.

FICTIONAL PROTOTYPE. Staged review answers from a fictional organisation. All figures are test fixtures, not an approved score.

The measurement framework

Each programme carries effectiveness measures drawn from the control designs behind it. These are the signals management should expect to see, not a claim that they exist today.

PROGRAMME	MEASURES	CONTROLS	ACCOUNTABLE FOR REPORTING
Supplier and payment integrity	7	7	Head of procurement
Fraud governance and risk identification	5	5	Risk function
Payroll integrity	3	3	HR
Incident response and evidence integrity	3	3	Head of forensics, risk
Identity and access challenge	2	2	HR
Stock and asset custody	2	2	Operations
Culture and continuous improvement	1	1	People, learning and ethics
Detection and exception review	1	1	Commercial
Cash custody	1	1	Operations

The individual measures are in Appendix F.

CONCLUSION

Management interpretation is added at generation. The analysis on this page stands without it.

FICTIONAL PROTOTYPE. Staged review answers from a fictional organisation. All figures are test fixtures, not an approved score.

Finding register

Every material finding the assessment produced. "Assessment indication" is what the responses record; it is self-reported and has not been verified.

ID	DOMAIN	ASSESSMENT INDICATION	MATERIALITY	FRAUD MECHANISM	RISK	CONTROL
MF-FS-D4-01 D4-O-01	Third parties and supply chain	Every new supplier goes through a defined process, with set checks and an approval, before it can be paid. Fictitious suppliers enter through onboarding that can be skipped.	assurance priority CRITICAL	An insider or outsider adds a supplier that does not exist and invoices it. The method links it to fictitious or shell suppliers, undisclosed conflicts of interest, misrepresented supplier credentials and duplicate or false invoices.	RISK-FS-D4-01	CI-FS-D4-01
MF-FS-D4-05 D4-V-01	Third parties and supply chain	Every invoice is checked against an approved order, quote or contract and against confirmation of receipt before payment, and differences are resolved first. Invoices paid without checking approval and receipt are how overbilling and fictitious deliveries get paid.	assurance priority CRITICAL	Overbilling, fictitious deliveries or inflated rates are paid. The method links it to unauthorised commitments and approval override, duplicate or false invoices, overpricing, overbilling and inflated variations, goods or services paid for but not received, counterfeit, substituted or substandard goods and misrepresented supplier credentials.	RISK-FS-D4-05	CI-FS-D4-05
MF-FS-D2-01 D2-G-01	Fraud risk assessment	Yes, in a dedicated fraud risk assessment Whether risks are understood decides whether controls are aimed at the right schemes.	assurance priority CRITICAL	Management does not know how fraud could happen in its own processes. The method links it to fraud schemes that are never identified, so no control is designed to stop them, effort and audit work not directed at the highest fraud risks, controls that do not match how fraud actually happens, blind spots in parts of the organisation or in types of fraud, an assessment that falls out of date as the business and threats change, management override of controls not considered, unable to show regulators, courts or funders that fraud risk was managed, fraud committed for the organisation's benefit goes unrecognised and AI-enabled fraud not anticipated.	RISK-FS-D2-01	CI-FS-D2-01
MF-FS-D3-10 D3-C-04	Ethics, integrity and anti-corruption	Yes, across everything it should cover Staff do not know or understand what is expected is a scheme the method asks about for organisations with this profile.	assurance priority	Expectations are not communicated in a way people understand, and nobody checks. The method links it to unclear standards, so misconduct is excused as normal practice, inconsistent consequences that signal the rules do not apply to everyone, staff unable to recognise fraud, including AI-enabled schemes and corporate criminal liability for bribery by people acting for the organisation.	RISK-FS-D3-10	CI-FS-D3-10
MF-FS-D5-02 D5-P-01	People, payroll and insider risk	The review follows a standard checklist, exceptions are followed up and findings are tracked over time. A payroll that nobody independent reviews before payment is where ghost employees hide.	assurance priority CRITICAL	Fictitious or departed people stay on the payroll. The method links it to ghost or fictitious employees and payees, unauthorised pay increases, allowances or deductions, salary redirection through changed bank details, manipulation of the payroll run or payment file, payments to people after they leave and false or inflated expense claims.	RISK-FS-D5-02	CI-FS-D5-02

MF-FS-D5-12 D5-K-01	People, payroll and insider risk	Compliance is monitored, and the work reviewed during leave is checked for irregularities. An insider in a high-risk role works unchecked is a scheme the method asks about for organisations with this profile.	assurance priority	Someone who never hands over work conceals an ongoing fraud. The method links it to concealment by people who control a process alone, misuse of privileged system access, false identity or credentials at hiring, insider fraud that goes unnoticed despite visible warning signs and payments to people after they leave.	RISK-FS-D5-12	CI-FS-D5-12
MF-FS-D3-11 D3-N-02	Ethics, integrity and anti-corruption	Partly: only in some areas, cases or periods Donations or sponsorships channel bribes is a scheme the method asks about for organisations with this profile.	control gap	A payment to a cause linked to a decision-maker buys influence. The method links it to donations and sponsorships used as disguised bribes, undeclared conflicts of interest steering decisions, corporate criminal liability for bribery by people acting for the organisation and bribes paid or received to win or keep business.	RISK-FS-D3-11	CI-FS-D3-11
MF-FS-D5-09 D5-L-05	People, payroll and insider risk	Partly: only in some areas, cases or periods Hours and overtime are inflated is a scheme the method asks about for organisations with this profile.	control gap	Unworked hours or overtime are approved and paid. The method links it to timesheet, overtime and leave abuse, payments to people after they leave and unauthorised pay increases, allowances or deductions.	RISK-FS-D5-09	CI-FS-D5-09
MF-FS-D2-02 D2-C-07	Fraud risk assessment	AI-enabled schemes, including deepfake instructions, synthetic identities and generated documents, are assessed for every relevant process. These schemes defeat controls that rely on recognising a person or a document.	assurance priority CRITICAL	Deepfake instructions, synthetic identities and generated documents are missing from management's view of fraud risk. The method links it to AI-enabled fraud not anticipated and controls that do not match how fraud actually happens.	RISK-FS-D2-02	CI-FS-D2-02
MF-FS-D8-01 D8-C-03	Assets, cash and inventory	Takings at every cash point are reconciled to sales records daily, and every shortage and surplus is investigated. Daily reconciliation of takings is the main control over cash theft.	assurance priority CRITICAL	Takings are under-recorded or removed before banking. The method links it to theft of cash, sales skimmed before they are recorded and fake proof of payment, deposit or delivery.	RISK-FS-D8-01	CI-FS-D8-01
MF-FS-D8-02 D8-K-02	Assets, cash and inventory	Every count is carried out or observed by people independent of the stores team, counting without sight of system quantities. Counts done by the people who hold the stock can hide its theft.	assurance priority CRITICAL	The people who hold stock also count it. The method links it to theft of stock and materials, false write-offs and adjustments that hide theft, short deliveries and theft in transit, organised theft of high-value materials and fake proof of payment, deposit or delivery.	RISK-FS-D8-02	CI-FS-D8-02
MF-FS-D1-01 D1-A-01	Fraud governance and accountability	Yes, it is written into a named executive's role Without a named, accountable person, other controls decay unnoticed.	assurance priority CRITICAL	Gaps persist because nobody owns fraud risk or has the authority to act. The method links it to no one accountable, so fraud risk goes unmanaged, under-resourced or unqualified fraud capability, management override of controls and unclear expectations and inconsistent responses to fraud.	RISK-FS-D1-01	CI-FS-D1-01
MF-FS-D4-13 D4-K-04	Third parties and supply chain	Yes, across everything it should cover Variations inflate the agreed value is a scheme the method asks about for organisations with this profile.	assurance priority	Extra scope or rates are approved after the work is done. The method links it to overpricing, overbilling and inflated variations, irregular deviations and emergency purchases, kickbacks and bribery, goods or services paid for but not received, diverted rebates and supplier incentives, undisclosed conflicts of interest and fictitious or shell suppliers.	RISK-FS-D4-13	CI-FS-D4-13

MF-FS-D10-05 D10-I-04	Detection, speak-up and response	Every investigation is done by people independent of the area and the people being investigated, and conflicts are declared. An investigation is not independent or fair is a scheme the method asks about for organisations with this profile.	assurance priority	The investigator is too close to the matter, or conclusions ignore other explanations. The method links it to investigations that cannot stand up in a hearing or in court, detection that misses AI-enabled schemes, reports that are lost, ignored or handled by people who are implicated and evidence destroyed, altered or inadmissible.	RISK-FS-D10-05	CI-FS-D10-05
MF-FS-D4-12 D4-V-15	Third parties and supply chain	Partly: only in some areas, cases or periods Procurement anomalies are never noticed is a scheme the method asks about for organisations with this profile.	control gap	Patterns such as splitting or duplicates go unseen. The method links it to order splitting to avoid approval limits, overpricing, overbilling and inflated variations, kickbacks and bribery and duplicate or false invoices.	RISK-FS-D4-12	CI-FS-D4-12
MF-FS-D5-01 D5-M-05	People, payroll and insider risk	Every change is confirmed through a channel the organisation starts, such as a call to a number on file or in person, before it takes effect. Salary redirection through fake bank change requests is common and fast.	assurance priority CRITICAL	A request that appears to come from an employee changes where their salary is paid. The method links it to salary redirection through changed bank details, ghost or fictitious employees and payees and unauthorised pay increases, allowances or deductions.	RISK-FS-D5-01	CI-FS-D5-01
MF-FS-D6-01 D6-P-02	Finance, banking and financial reporting	The bank's platform enforces two authorisers for every payment. Two-person release enforced where money leaves is the last barrier before a payment goes.	assurance priority CRITICAL	One person can release money, on the platform or through a branch instruction. The method links it to unauthorised payments from the organisation's bank accounts, payments to fraudulent or altered beneficiaries, unauthorised changes to bank mandates or company records and concealment in unreconciled accounts and suspense balances.	RISK-FS-D6-01	CI-FS-D6-01
MF-FS-D7-01 D7-R-01	Customers, revenue and products	The system enforces the approval, and approvals are reviewed for patterns. Refunds processed and approved by one person are a classic way to steal.	assurance priority CRITICAL	One person raises and approves refunds or credit notes to themselves or accomplices. The method links it to false refunds, credit notes and returns, stolen or diverted customer payments, including lapping and fictitious sales and commission fraud.	RISK-FS-D7-01	CI-FS-D7-01
MF-FS-D10-01 D10-N-01	Detection, speak-up and response	All employees know at least two people they can tell, including one outside their reporting line, and that the Protected Disclosures Act protects them. Tips are the most common way fraud is detected, and safe routes decide whether people report.	assurance priority CRITICAL	People who suspect fraud have no safe route, or do not know whom to tell. The method links it to fraud that nobody reports because there is no trusted way to do so, failure to meet legal duties to respond to disclosures and report crimes, reports that are lost, ignored or handled by people who are implicated and retaliation that silences people who speak up.	RISK-FS-D10-01	CI-FS-D10-01
MF-FS-D10-02 D10-P-01	Detection, speak-up and response	Reporters' identities are kept confidential, and access to reports is limited to a few named people. Confidentiality and protection from retaliation decide whether anyone reports again; reporter confidentiality added after the review's isolated-weakness probe.	assurance priority CRITICAL	A reporter's identity leaks or they are penalised, and others stop reporting. The method links it to retaliation that silences people who speak up, failure to meet legal duties to respond to disclosures and report crimes, fraud that nobody reports because there is no trusted way to do so and evidence destroyed, altered or inadmissible.	RISK-FS-D10-02	CI-FS-D10-02

MF-FS-D3-01 D3-B-01	Ethics, integrity and anti-corruption	The rule covers every form of bribery, including through agents, applies to everyone acting for the organisation and is communicated. PRECCA criminalises bribery in both sectors, including bribes paid through others.	assurance priority CRITICAL	Staff or intermediaries offer or accept gratification to win or retain business. The method links it to bribes paid or received to win or keep business, corporate criminal liability for bribery by people acting for the organisation and AI used to fabricate documents, evidence or identities.	RISK-FS-D3-01	CI-FS-D3-01
MF-FS-D9-01 D9-E-01	Digital, cyber-enabled and identity fraud	Multi-factor authentication is required for every email account, including executives' and shared mailboxes, with no exceptions. Most business email compromise starts with an account that has no multi-factor authentication.	assurance priority CRITICAL	A mailbox without strong sign-in is used to send or intercept payment instructions. The method links it to takeover of staff accounts, business email compromise and payment redirection, spoofed or lookalike email in the organisation's name, criminals impersonating the organisation to customers, suppliers and the public and slow response that lets losses grow.	RISK-FS-D9-01	CI-FS-D9-01
MF-FS-D2-05 D2-P-01	Fraud risk assessment	The effect of each response is checked, and the response is revisited if the risk does not come down. Risks above tolerance are left without action is a scheme the method asks about for organisations with this profile.	assurance priority	Assessment results do not change controls, audit work or training. The method links it to effort and audit work not directed at the highest fraud risks, controls that do not match how fraud actually happens and unable to show regulators, courts or funders that fraud risk was managed.	RISK-FS-D2-05	CI-FS-D2-05
MF-FS-D2-06 D2-M-02	Fraud risk assessment	Change projects include a fraud risk step by default, and the assessment owner confirms the update is complete. The assessment goes stale as the business changes is a scheme the method asks about for organisations with this profile.	assurance priority	New products, structures and threats are not assessed. The method links it to an assessment that falls out of date as the business and threats change, AI-enabled fraud not anticipated, fraud schemes that are never identified, so no control is designed to stop them, unable to show regulators, courts or funders that fraud risk was managed, controls that do not match how fraud actually happens, blind spots in parts of the organisation or in types of fraud and effort and audit work not directed at the highest fraud risks.	RISK-FS-D2-06	CI-FS-D2-06
MF-FS-D8-11 D8-M-01	Assets, cash and inventory	Partly: only in some areas, cases or periods Losses are never tracked is a scheme the method asks about for organisations with this profile.	control gap	Shrinkage and losses are written off without analysis. The method links it to theft of cash, theft of stock and materials and misappropriation of fixed and portable assets.	RISK-FS-D8-11	CI-FS-D8-11

FICTIONAL PROTOTYPE. Staged review answers from a fictional organisation. All figures are test fixtures, not an approved score.

Fraud risk register

Risks implied by the assessed control positions. No likelihood, monetary value or incident frequency is assigned, because the assessment does not support one.

ID	RISK	CURRENT CONTROL POSITION	REQUIRED TREATMENT	OWNER ROLE
RISK-FS-D1-01 MF-FS-D1-01	**Because its control is reported in place while owner has authority across the organisation (not in place), dedicated fraud capability (only in some areas, cases or periods) and annual fraud action plan (only in some areas, cases or periods), there is a risk that gaps persist because nobody owns fraud risk or has the authority to act. Without a named, accountable person, other controls decay unnoticed.**	Owner has authority across the organisation: not in place. Dedicated fraud capability: only in some areas, cases or periods. Annual fraud action plan: only in some areas, cases or periods. Qualified fraud leads: only in some areas, cases or periods.	Owner has authority across the organisation: the answer to "Does the person who handles fraud risk have the authority and budget to act across the organisation, not only in their own area?" is yes, across everything it should cover. Dedicated fraud capability: the answer to "Is there a dedicated fraud risk or forensic function, or a defined external provider that fills that role?" is yes, across everything it should cover. Annual fraud action plan: the answer to "Is there an annual plan or budget for fraud risk work?" is yes, across everything it should cover. Qualified fraud leads: the answer to "Do the people who lead fraud risk work hold recognised training or qualifications, such as the CFE or forensic training?" is yes, across everything it should cover.	CEO or company secretary
RISK-FS-D2-01 MF-FS-D2-01	**Because its control is reported in place while management owns the results (not in place), process owners take part (not in place) and processes walked through (not in place), there is a risk that management does not know how fraud could happen in its own processes. Whether risks are understood decides whether controls are aimed at the right schemes.**	Management has not seen or accepted the results. Process owners take part: not in place. Processes walked through: not in place. Some risks describe a scheme, but most remain general.	Management formally accepts the results, and every significant risk has a named owner who has agreed to it. Process owners take part: the answer to "Do the people who run the processes take part, for example in workshops or interviews?" is yes, across everything it should cover. Processes walked through: the answer to "Does the assessment walk through each high-risk process step by step to find where fraud could happen?" is yes, across everything it should cover. Every risk is described as a specific scheme, with the perpetrator, the method and the process it affects.	Risk manager or fraud risk lead
RISK-FS-D2-02 MF-FS-D2-02	**Because its control is reported in place while controls tested against AI fakes (not in place), AI methods tested per process (not in place) and own AI tools in scope (only in some areas, cases or periods), there is a risk that deepfake instructions, synthetic identities and generated documents are missing from management's view of fraud risk. These schemes defeat controls that rely on recognising a person or a document.**	Controls tested against AI fakes: not in place. AI methods tested per process: not in place. Own AI tools in scope: only in some areas, cases or periods. Simulated AI attack: only in some areas, cases or periods.	Controls tested against AI fakes: the answer to "Are controls that rely on recognising a voice, face, signature or document assessed for whether an AI-generated fake could defeat them?" is yes, across everything it should cover. AI methods tested per process: the answer to "For each high-risk process, does the assessment ask how AI could be used against it, for example whether a cloned voice could pass a call-back check?" is yes, across everything it should cover. Own AI tools in scope: the answer to "Does it consider how the organisation's own AI tools, such as chatbots or automated approvals, could be manipulated or misused?" is yes, across everything it should cover. Simulated AI attack: the answer to "Has the organisation tested its verification controls with a simulated AI attack, such as a staged deepfake call to the finance team?" is yes, across everything it should cover.	Risk manager or fraud risk lead
RISK-FS-D2-05 MF-FS-D2-05	**Because its control is reported in place while likelihood and impact rated (not in place), there is a risk that assessment results do not change controls, audit work or training.**	Likelihood and impact rated: not in place.	Likelihood and impact rated: the answer to "Is each fraud risk rated for how likely it is and how much harm it could cause?" is yes, across everything it should cover.	Risk manager or fraud risk lead

ID	Risk	Position	Required treatment	Owner role
RISK-FS-D2-06 MF-FS-D2-06	**Because its control is reported in place while owners know their risks (not in place) and assessment documented (only in some areas, cases or periods), there is a risk that new products, structures and threats are not assessed.**	Owners know their risks: not in place. Assessment documented: only in some areas, cases or periods.	Owners know their risks: the answer to "Do the people who run each process know the fraud risks recorded for their area?" is yes, across everything it should cover. Assessment documented: the answer to "Is the assessment documented, showing the risks, ratings, controls and decisions taken?" is yes, across everything it should cover.	Risk manager or fraud risk lead
RISK-FS-D3-01 MF-FS-D3-01	**Because its control is reported in place while leaders trained on their duties (set out but not yet working in practice) and high-risk activities identified (only in some areas, cases or periods), there is a risk that staff or intermediaries offer or accept gratification to win or retain business. PRECCA criminalises bribery in both sectors, including bribes paid through others.**	Leaders trained on their duties: set out but not yet working in practice. The main high-risk activities are identified, and some have extra controls.	Leaders trained on their duties: the answer to "Are directors and senior managers trained on their personal duties, including reporting corruption under section 34 and the organisation's liability for bribery?" is yes, across everything it should cover. All high-risk activities, such as winning work, licences, customs and inspections, are identified and have specific extra controls.	Ethics officer or company secretary
RISK-FS-D3-10 MF-FS-D3-10	**Because its control is reported in place while written code of conduct (not in place), programme independently reviewed (not in place) and trends reported upward (not in place), there is a risk that expectations are not communicated in a way people understand, and nobody checks.**	Written code of conduct: not in place. Programme independently reviewed: not in place. Trends reported upward: not in place. Training on joining: set out but not yet working in practice.	Written code of conduct: the answer to "Does the organisation have a written code of conduct?" is yes, across everything it should cover. Programme independently reviewed: the answer to "Is the ethics and anti-bribery programme reviewed for whether it works, for example by internal audit or an independent reviewer?" is yes, across everything it should cover. Trends reported upward: the answer to "Are trends in declarations, gifts registers and ethics breaches reported to the board, council, social and ethics committee or owners?" is yes, across everything it should cover. Training on joining: the answer to "Do all employees receive fraud and ethics training when they join?" is yes, across everything it should cover.	Ethics officer or company secretary
RISK-FS-D3-11 MF-FS-D3-11	**Because the controls that stop it were reported as gaps: recipients checked for links (only in some areas, cases or periods), there is a risk that a payment to a cause linked to a decision-maker buys influence.**	Recipients checked for links: only in some areas, cases or periods.	Recipients checked for links: the answer to "Are recipients checked for links to public officials, customers' decision-makers and employees before money is committed?" is yes, across everything it should cover.	Ethics officer or company secretary
RISK-FS-D4-01 MF-FS-D4-01	**Because its control is reported in place while new supplier approved by another person (not in place), directors compared with staff (not in place) and dormant suppliers deactivated (not in place), there is a risk that an insider or outsider adds a supplier that does not exist and invoices it. Fictitious suppliers enter through onboarding that can be skipped.**	New supplier approved by another person: not in place. Directors compared with staff: not in place. Dormant suppliers deactivated: not in place. Suppliers re-checked: set out but not yet working in practice. Owners are identified only when something raises a concern.	New supplier approved by another person: the answer to "Does someone other than the person who captured a new supplier approve it before it becomes active?" is yes, across everything it should cover. Directors compared with staff: the answer to "Do you compare supplier directors, owners, addresses or bank accounts with your employee records?" is yes, across everything it should cover. Dormant suppliers deactivated: the answer to "Are suppliers that have not been used for a set period deactivated?" is yes, across everything it should cover. Suppliers re-checked: the answer to "Are existing suppliers re-checked periodically, not only when they are first added?" is yes, across everything it should cover. Directors and owners, including those behind holding companies, are identified for every new supplier from an independent source.	Head of procurement or CFO

ID	RISK	POSITION	REQUIRED TREATMENT	OWNER ROLE
RISK-FS-D4-05 MF-FS-D4-05	**Because its control is reported in place while services confirmed (not in place), approved order before commitment (only in some areas, cases or periods) and receipt recorded before payment (only in some areas, cases or periods), there is a risk that overbilling, fictitious deliveries or inflated rates are paid. Invoices paid without checking approval and receipt are how overbilling and fictitious deliveries get paid.**	Services confirmed: not in place. Most purchases are approved before commitment, through a purchase order or another record. Receipt is recorded for most deliveries, but not always before payment.	Services confirmed: the answer to "For services, does the person receiving the service confirm it was delivered before payment?" is yes, across everything it should cover. Every purchase is approved by someone with the authority to do so before the organisation commits, and the approval is recorded. Receipt is always recorded before the related invoice is paid.	Head of procurement or CFO
RISK-FS-D4-12 MF-FS-D4-12	**Because the controls that stop it were reported as gaps: senior review of supplier payments (only in some areas, cases or periods), data reviewed for unusual patterns (not in place), split orders monitored (set out but not yet working in practice) and independent review of procurement (only in some areas, cases or periods), there is a risk that patterns such as splitting or duplicates go unseen.**	Senior review of supplier payments: only in some areas, cases or periods. Data reviewed for unusual patterns: not in place. Split orders monitored: set out but not yet working in practice. Independent review of procurement: only in some areas, cases or periods.	Senior review of supplier payments: the answer to "Does someone senior review a list of supplier payments at least once a month?" is yes, across everything it should cover. Data reviewed for unusual patterns: the answer to "Does anyone regularly review procurement and supplier payment data for unusual patterns?" is yes, across everything it should cover. Split orders monitored: the answer to "Do you monitor for several smaller orders to the same supplier that together exceed an approval limit?" is yes, across everything it should cover. Independent review of procurement: the answer to "Has internal audit or an external reviewer examined procurement in the last two years?" is yes, across everything it should cover.	Head of procurement or CFO
RISK-FS-D4-13 MF-FS-D4-13	**Because its control is reported in place while contract register (not in place), large variations escalated (set out but not yet working in practice) and written supplier contracts (only in some areas, cases or periods), there is a risk that extra scope or rates are approved after the work is done.**	Contract register: not in place. Large variations escalated: set out but not yet working in practice. Written supplier contracts: only in some areas, cases or periods.	Contract register: the answer to "Is there a register of all active supplier contracts?" is yes, across everything it should cover. Large variations escalated: the answer to "Are variations above a set percentage of the original value approved at a higher level?" is yes, across everything it should cover. Written supplier contracts: the answer to "Does the organisation sign written contracts with suppliers for ongoing or significant work?" is yes, across everything it should cover.	Head of procurement or CFO
RISK-FS-D5-01 MF-FS-D5-01	**Because its control is reported in place while bank change report reviewed (only in some areas, cases or periods), there is a risk that a request that appears to come from an employee changes where their salary is paid. Salary redirection through fake bank change requests is common and fast.**	Bank change report reviewed: only in some areas, cases or periods.	Bank change report reviewed: the answer to "Is a report of employee bank detail changes reviewed before each pay run?" is yes, across everything it should cover.	HR or payroll manager
RISK-FS-D5-02 MF-FS-D5-02	**Because its control is reported in place while payroll data analysed (set out but not yet working in practice), new employee checked by another person (only in some areas, cases or periods) and independent review of payroll (only in some areas, cases or periods), there is a risk that fictitious or departed people stay on the payroll. A payroll that nobody independent reviews before payment is where ghost employees hide.**	Payroll data analysed: set out but not yet working in practice. The person who captures the record checks it themselves. Independent review of payroll: only in some areas, cases or periods.	Payroll data analysed: the answer to "Does anyone analyse payroll data for unusual patterns?" is yes, across everything it should cover. Every new record is checked against a signed appointment by someone other than the person who captured it, before the first pay run. Independent review of payroll: the answer to "Has internal audit or an external reviewer examined payroll in the last two years?" is yes, across everything it should cover.	HR or payroll manager
RISK-FS-D5-09 MF-FS-D5-09	**Because the controls that stop it were reported as gaps: hours approved by supervisor (only in some areas, cases or periods), there is a risk that unworked hours or overtime are approved and paid.**	Hours approved by supervisor: only in some areas, cases or periods.	Hours approved by supervisor: the answer to "Are hours approved by a supervisor before they are paid?" is yes, across everything it should cover.	HR or payroll manager

ID	RISK	POSITION	REQUIRED TREATMENT	OWNER ROLE
RISK-FS-D5-12 MF-FS-D5-12	**Because its control is reported in place while concerns raised fairly (not in place), support for financial pressure (not in place) and no conflicting duties when covering (set out but not yet working in practice), there is a risk that someone who never hands over work conceals an ongoing fraud.**	Concerns raised fairly: not in place. Support for financial pressure: not in place. No conflicting duties when covering: set out but not yet working in practice. Managers know informally which roles are risky.	Concerns raised fairly: the answer to "Is there a defined way for managers to raise and escalate concerns about an employee's behaviour, confidentially and without making accusations?" is yes, across everything it should cover. Support for financial pressure: the answer to "Does the organisation offer support to employees in financial difficulty, such as financial wellness or employee assistance programmes?" is yes, across everything it should cover. No conflicting duties when covering: the answer to "Are people in high-risk roles, such as those who can move money or change master data, kept from holding conflicting duties, even temporarily when they cover for colleagues?" is yes, across everything it should cover. A maintained list of high-risk roles covers the whole organisation, including roles that can move money, change master data or manage system access.	HR or payroll manager
RISK-FS-D6-01 MF-FS-D6-01	**Because its control is reported in place while capture and authorise separated (not in place), there is a risk that one person can release money, on the platform or through a branch instruction. Two-person release enforced where money leaves is the last barrier before a payment goes.**	Users can capture payments, load beneficiaries and authorise.	Platform roles ensure that no one who captures payments or loads beneficiaries can authorise them.	CFO or financial manager
RISK-FS-D7-01 MF-FS-D7-01	**Because its control is reported in place while refunds to the original source (not in place), there is a risk that one person raises and approves refunds or credit notes to themselves or accomplices. Refunds processed and approved by one person are a classic way to steal.**	Refunds are paid wherever the customer asks.	Every refund goes to the original payment method or to a customer account verified before payment.	Commercial or finance manager
RISK-FS-D8-01 MF-FS-D8-01	**Because its control is reported in place while dual control at hand-overs (only in some areas, cases or periods), takings checked against an independent record (only in some areas, cases or periods) and deposits reconciled independently (only in some areas, cases or periods), there is a risk that takings are under-recorded or removed before banking. Daily reconciliation of takings is the main control over cash theft.**	Cash is counted at some handovers, such as at the end of the day, but not at shift changes. Takings checked against an independent record: only in some areas, cases or periods. Deposits are checked against the statement occasionally.	Whenever cash changes hands, two people count it, record it and sign for it. Takings checked against an independent record: the answer to "Are takings reconciled to an independent record of activity, such as till rolls, ticket numbers, meter readings or occupancy, and not only to what the cashier records?" is yes, across everything it should cover. Every deposit and collection is reconciled to the bank statement by someone who does not handle the cash, using statements obtained directly from the bank.	Operations or financial manager

ID	Risk	Position	Required treatment	Owner role
RISK-FS-D8-02 MF-FS-D8-02	**Because its control is reported in place while how stock is recorded (not in place), store access limited (not in place) and issues against approved requests (not in place), there is a risk that the people who hold stock also count it. Counts done by the people who hold the stock can hide its theft.**	How stock is recorded: not in place. Store access limited: not in place. Issues against approved requests: not in place. Differences explained before adjusting: not in place. High-value items secured: set out but not yet working in practice.	How stock is recorded: the answer to "How is stock recorded?" is yes, across everything it should cover. Store access limited: the answer to "Is access to stores and warehouses limited to authorised people, with visitors and contractors recorded?" is yes, across everything it should cover. Issues against approved requests: the answer to "Are stock issues and transfers recorded against an approved requisition or order before goods leave the store?" is yes, across everything it should cover. Differences explained before adjusting: the answer to "Are count differences investigated and explained before the records are adjusted?" is yes, across everything it should cover. High-value items secured: the answer to "Are high-value or easily resold items kept in a secure area with extra controls, such as cages, seals or serial number tracking?" is yes, across everything it should cover.	Operations or financial manager
RISK-FS-D8-11 MF-FS-D8-11	**Because the controls that stop it were reported as gaps: losses tracked and reported (only in some areas, cases or periods), there is a risk that shrinkage and losses are written off without analysis.**	Losses tracked and reported: only in some areas, cases or periods.	Losses tracked and reported: the answer to "Are losses of cash, stock and assets tracked over time and by location, and reported to management?" is yes, across everything it should cover.	Operations or financial manager
RISK-FS-D9-01 MF-FS-D9-01	**Because its control is reported in place while mailbox rules and odd logins alerted (not in place), there is a risk that a mailbox without strong sign-in is used to send or intercept payment instructions. Most business email compromise starts with an account that has no multi-factor authentication.**	Mailbox rules and odd logins alerted: not in place.	Mailbox rules and odd logins alerted: the answer to "Are new forwarding or inbox rules, and logins from unusual locations, alerted and reviewed?" is yes, across everything it should cover.	Head of IT or IT provider
RISK-FS-D10-01 MF-FS-D10-01	**Because its control is reported in place while speak-up channel (only in some areas, cases or periods), there is a risk that people who suspect fraud have no safe route, or do not know whom to tell. Tips are the most common way fraud is detected, and safe routes decide whether people report.**	Speak-up channel: only in some areas, cases or periods.	Speak-up channel: the answer to "Does the organisation have a speak-up or whistleblowing channel?" is yes, across everything it should cover.	Head of forensics, risk or compliance
RISK-FS-D10-02 MF-FS-D10-02	**Because its control is reported in place while retaliation risk assessed (only in some areas, cases or periods), there is a risk that a reporter's identity leaks or they are penalised, and others stop reporting. Confidentiality and protection from retaliation decide whether anyone reports again; reporter confidentiality added after the review's isolated-weakness probe.**	Retaliation risk assessed: only in some areas, cases or periods.	Retaliation risk assessed: the answer to "When a report is received, is the reporter's risk of retaliation or harm assessed, and are protective steps taken where needed?" is yes, across everything it should cover.	Head of forensics, risk or compliance
RISK-FS-D10-05 MF-FS-D10-05	**Because its control is reported in place while who investigates (only in some areas, cases or periods), there is a risk that the investigator is too close to the matter, or conclusions ignore other explanations.**	Who investigates: only in some areas, cases or periods.	Who investigates: the answer to "Who investigates suspected fraud?" is yes, across everything it should cover.	Head of forensics, risk or compliance

FICTIONAL PROTOTYPE. Staged review answers from a fictional organisation. All figures are test fixtures, not an approved score.

Control blueprint register

Recommended control standard for each finding. This is MK methodology: what good practice requires, not a description of what the organisation currently operates. The assessed state column records what the organisation reported for that control.

ASSESSED STATE KEY

- Owner has authority across the organisation: not in place. Dedicated fraud capability: only in some areas, cases or periods. Annual fraud action plan: only in some areas, cases or periods. Qualified fraud leads: only in some areas, cases or periods.
- Management has not seen or accepted the results. Process owners take part: not in place. Processes walked through: not in place. Some risks describe a scheme, but most remain general.
- Controls tested against AI fakes: not in place. AI methods tested per process: not in place. Own AI tools in scope: only in some areas, cases or periods. Simulated AI attack: only in some areas, cases or periods.
- Likelihood and impact rated: not in place.
- Owners know their risks: not in place. Assessment documented: only in some areas, cases or periods.
- Leaders trained on their duties: set out but not yet working in practice. The main high-risk activities are identified, and some have extra controls.
- Written code of conduct: not in place. Programme independently reviewed: not in place. Trends reported upward: not in place. Training on joining: set out but not yet working in practice.
- Recipients checked for links: only in some areas, cases or periods.
- New supplier approved by another person: not in place. Directors compared with staff: not in place. Dormant suppliers deactivated: not in place. Suppliers re-checked: set out but not yet working in practice. Owners are identified only when something raises a concern.
- Services confirmed: not in place. Most purchases are approved before commitment, through a purchase order or another record. Receipt is recorded for most deliveries, but not always before payment.
- Senior review of supplier payments: only in some areas, cases or periods. Data reviewed for unusual patterns: not in place. Split orders monitored: set out but not yet working in practice. Independent review of procurement: only in some areas, cases or periods.
- Contract register: not in place. Large variations escalated: set out but not yet working in practice. Written supplier contracts: only in some areas, cases or periods.
- Bank change report reviewed: only in some areas, cases or periods.
- Payroll data analysed: set out but not yet working in practice. The person who captures the record checks it themselves. Independent review of payroll: only in some areas, cases or periods.
- Hours approved by supervisor: only in some areas, cases or periods.
- Concerns raised fairly: not in place. Support for financial pressure: not in place. No conflicting duties when covering: set out but not yet working in practice. Managers know informally which roles are risky.
- Users can capture payments, load beneficiaries and authorise.
- Refunds are paid wherever the customer asks.
- Cash is counted at some handovers, such as at the end of the day, but not at shift changes. Takings checked against an independent record: only in some areas, cases or periods. Deposits are checked against the statement occasionally.
- How stock is recorded: not in place. Store access limited: not in place. Issues against approved requests: not in place. Differences explained before adjusting: not in place. High-value items secured: set out but not yet working in practice.
- Losses tracked and reported: only in some areas, cases or periods.
- Mailbox rules and odd logins alerted: not in place.
- Speak-up channel: only in some areas, cases or periods.
- Retaliation risk assessed: only in some areas, cases or periods.
- Who investigates: only in some areas, cases or periods.

FICTIONAL PROTOTYPE. Staged review answers from a fictional organisation. All figures are test fixtures, not an approved score.

ID	OBJECTIVE	RECOMMENDED DESIGN	ASSESSED	OVERSIGHT	FREQUENCY	TEST
CI-FS-D1-01 D1-A-01 30 days	**Stop the scheme where no one is answerable for fraud risk.**	1. Owner has authority across the organisation: the answer to "Does the person who handles fraud risk have the authority and budget to act across the organisation, not only in their own area?" is yes, across everything it should cover. 2. Dedicated fraud capability: the answer to "Is there a dedicated fraud risk or forensic function, or a defined external provider that fills that role?" is yes, across everything it should cover. 3. Annual fraud action plan: the answer to "Is there an annual plan or budget for fraud risk work?" is yes, across everything it should cover. 4. Qualified fraud leads: the answer to "Do the people who lead fraud risk work hold recognised training or qualifications, such as the CFE or forensic training?" is yes, across everything it should cover.	STATE 1	CEO or company secretary The board or its audit committee	Annual review of mandates	Management's own records show that every case in the period passes this test: Does the person who handles fraud risk have the authority and budget to act across the organisation, not only in their own area?
CI-FS-D2-01 D2-G-01 30 days	**Stop the scheme where fraud risks are never identified.**	1. Management owns the results: Management formally accepts the results, and every significant risk has a named owner who has agreed to it. 2. Process owners take part: the answer to "Do the people who run the processes take part, for example in workshops or interviews?" is yes, across everything it should cover. 3. Processes walked through: the answer to "Does the assessment walk through each high-risk process step by step to find where fraud could happen?" is yes, across everything it should cover. 4. Risks described as schemes: Every risk is described as a specific scheme, with the perpetrator, the method and the process it affects.	STATE 2	Risk manager or fraud risk lead The board or its audit committee	As each case arises, with a monthly review by the process owner	Management's own records show, for every case in the period: management formally accepts the results, and every significant risk has a named owner who has agreed to it.
CI-FS-D2-02 D2-C-07 30 days	**Stop the scheme where AI-enabled schemes are not considered.**	1. Controls tested against AI fakes: the answer to "Are controls that rely on recognising a voice, face, signature or document assessed for whether an AI-generated fake could defeat them?" is yes, across everything it should cover. 2. AI methods tested per process: the answer to "For each high-risk process, does the assessment ask how AI could be used against it, for example whether a cloned voice could pass a call-back check?" is yes, across everything it should cover. 3. Own AI tools in scope: the answer to "Does it consider how the organisation's own AI tools, such as chatbots or automated approvals, could be manipulated or misused?" is yes, across everything it should cover. 4. Simulated AI attack: the answer to "Has the organisation tested its verification controls with a simulated AI attack, such as a staged deepfake call to the finance team?" is yes, across everything it should cover.	STATE 3	Risk manager or fraud risk lead The board or its audit committee	As each case arises, with a monthly review by the process owner	Management's own records show that every case in the period passes this test: Are controls that rely on recognising a voice, face, signature or document assessed for whether an AI-generated fake could defeat them?

ID	Objective	Recommended design	Assessed	Oversight	Frequency	Test
CI-FS-D2-05 D2-P-01 90 days	**Stop the scheme where risks above tolerance are left without action.**	1. Likelihood and impact rated: the answer to "Is each fraud risk rated for how likely it is and how much harm it could cause?" is yes, across everything it should cover.	STATE 4	Risk manager or fraud risk lead The board or its audit committee	As each case arises, with a monthly review by the process owner	Management's own records show that every case in the period passes this test: Is each fraud risk rated for how likely it is and how much harm it could cause?
CI-FS-D2-06 D2-M-02 90 days	**Stop the scheme where the assessment goes stale as the business changes.**	1. Owners know their risks: the answer to "Do the people who run each process know the fraud risks recorded for their area?" is yes, across everything it should cover. 2. Assessment documented: the answer to "Is the assessment documented, showing the risks, ratings, controls and decisions taken?" is yes, across everything it should cover.	STATE 5	Risk manager or fraud risk lead The board or its audit committee	As each case arises, with a monthly review by the process owner	Management's own records show that every case in the period passes this test: Do the people who run each process know the fraud risks recorded for their area?
CI-FS-D3-01 D3-B-01 30 days	**Stop the scheme where bribes are paid or accepted, directly or through others.**	1. Leaders trained on their duties: the answer to "Are directors and senior managers trained on their personal duties, including reporting corruption under section 34 and the organisation's liability for bribery?" is yes, across everything it should cover. 2. High-risk activities identified: All high-risk activities, such as winning work, licences, customs and inspections, are identified and have specific extra controls.	STATE 6	Compliance or legal lead The board or its audit committee	As each case arises, with a monthly review by the process owner	Management's own records show that every case in the period passes this test: Are directors and senior managers trained on their personal duties, including reporting corruption under section 34 and the organisation's liability for bribery?
CI-FS-D3-10 D3-C-04 90 days	**Stop the scheme where staff do not know or understand what is expected.**	1. Written code of conduct: the answer to "Does the organisation have a written code of conduct?" is yes, across everything it should cover. 2. Programme independently reviewed: the answer to "Is the ethics and anti-bribery programme reviewed for whether it works, for example by internal audit or an independent reviewer?" is yes, across everything it should cover. 3. Trends reported upward: the answer to "Are trends in declarations, gifts registers and ethics breaches reported to the board, council, social and ethics committee or owners?" is yes, across everything it should cover. 4. Training on joining: the answer to "Do all employees receive fraud and ethics training when they join?" is yes, across everything it should cover.	STATE 7	HR lead or ethics officer The board or its audit committee	As each case arises, with a monthly review by the process owner	Management's own records show that every case in the period passes this test: Does the organisation have a written code of conduct?
CI-FS-D3-11 D3-N-02 90 days	**Stop the scheme where donations or sponsorships channel bribes.**	1. Recipients checked for links: the answer to "Are recipients checked for links to public officials, customers' decision-makers and employees before money is committed?" is yes, across everything it should cover.	STATE 8	CSI or sustainability lead The board or its audit committee	As each case arises, with a monthly review by the process owner	Management's own records show that every case in the period passes this test: Are recipients checked for links to public officials, customers' decision-makers and employees before money is committed?

ID	Objective	Recommended design	Assessed	Oversight	Frequency	Test
CI-FS-D4-01 D4-O-01 30 days	**Stop the scheme where a fictitious supplier is created and paid.**	1. New supplier approved by another person: the answer to "Does someone other than the person who captured a new supplier approve it before it becomes active?" is yes, across everything it should cover. 2. Directors compared with staff: the answer to "Do you compare supplier directors, owners, addresses or bank accounts with your employee records?" is yes, across everything it should cover. 3. Dormant suppliers deactivated: the answer to "Are suppliers that have not been used for a set period deactivated?" is yes, across everything it should cover. 4. Suppliers re-checked: the answer to "Are existing suppliers re-checked periodically, not only when they are first added?" is yes, across everything it should cover. 5. Directors identified: Directors and owners, including those behind holding companies, are identified for every new supplier from an independent source.	STATE 9	Procurement or creditors manager The board or its audit committee	Every new supplier, customer or employee before activation	Management's own records show that every case in the period passes this test: Does someone other than the person who captured a new supplier approve it before it becomes active?
CI-FS-D4-05 D4-V-01 30 days	**Stop the scheme where invoices are paid for goods or services not received or not agreed.**	1. Services confirmed: the answer to "For services, does the person receiving the service confirm it was delivered before payment?" is yes, across everything it should cover. 2. Approved order before commitment: Every purchase is approved by someone with the authority to do so before the organisation commits, and the approval is recorded. 3. Receipt recorded before payment: Receipt is always recorded before the related invoice is paid.	STATE 10	Creditors manager or financial controller The board or its audit committee	Every payment run	Management's own records show that every case in the period passes this test: For services, does the person receiving the service confirm it was delivered before payment?
CI-FS-D4-12 D4-V-15 90 days	**Stop the scheme where procurement anomalies are never noticed.**	1. Senior review of supplier payments: the answer to "Does someone senior review a list of supplier payments at least once a month?" is yes, across everything it should cover. 2. Data reviewed for unusual patterns: the answer to "Does anyone regularly review procurement and supplier payment data for unusual patterns?" is yes, across everything it should cover. 3. Split orders monitored: the answer to "Do you monitor for several smaller orders to the same supplier that together exceed an approval limit?" is yes, across everything it should cover. 4. Independent review of procurement: the answer to "Has internal audit or an external reviewer examined procurement in the last two years?" is yes, across everything it should cover.	STATE 11	Creditors manager or financial controller The board or its audit committee	Every payment run	Management's own records show that every case in the period passes this test: Does someone senior review a list of supplier payments at least once a month?
CI-FS-D4-13 D4-K-04 90 days	**Stop the scheme where variations inflate the agreed value.**	1. Contract register: the answer to "Is there a register of all active supplier contracts?" is yes, across everything it should cover. 2. Large variations escalated: the answer to "Are variations above a set percentage of the original value approved at a higher level?" is yes, across everything it should cover. 3. Written supplier contracts: the answer to "Does the organisation sign written contracts with suppliers for ongoing or significant work?" is yes, across everything it should cover.	STATE 12	Procurement or the finance manager The board or its audit committee	As each case arises, with a monthly review by the process owner	Management's own records show that every case in the period passes this test: Is there a register of all active supplier contracts?

FICTIONAL PROTOTYPE. Staged review answers from a fictional organisation. All figures are test fixtures, not an approved score.

ID	Objective	Recommended design	Assessed	Oversight	Frequency	Test
CI-FS-D5-01 D5-M-05 30 days	**Stop the scheme where salaries are redirected through a fake bank change.**	1. Bank change report reviewed: the answer to "Is a report of employee bank detail changes reviewed before each pay run?" is yes, across everything it should cover.	STATE 13	Payroll manager The board or its audit committee	As each case arises, with a monthly review by the process owner	Management's own records show that every case in the period passes this test: Is a report of employee bank detail changes reviewed before each pay run?
CI-FS-D5-02 D5-P-01 30 days	**Stop the scheme where ghost employees are paid.**	1. Payroll data analysed: the answer to "Does anyone analyse payroll data for unusual patterns?" is yes, across everything it should cover. 2. New employee checked by another person: Every new record is checked against a signed appointment by someone other than the person who captured it, before the first pay run. 3. Independent review of payroll: the answer to "Has internal audit or an external reviewer examined payroll in the last two years?" is yes, across everything it should cover.	STATE 14	Payroll manager or financial controller The board or its audit committee	Every pay run	Management's own records show that every case in the period passes this test: Does anyone analyse payroll data for unusual patterns?
CI-FS-D5-09 D5-L-05 90 days	**Stop the scheme where hours and overtime are inflated.**	1. Hours approved by supervisor: the answer to "Are hours approved by a supervisor before they are paid?" is yes, across everything it should cover.	STATE 15	HR or payroll manager The board or its audit committee	As each case arises, with a monthly review by the process owner	Management's own records show that every case in the period passes this test: Are hours approved by a supervisor before they are paid?
CI-FS-D5-12 D5-K-01 90 days	**Stop the scheme where an insider in a high-risk role works unchecked.**	1. Concerns raised fairly: the answer to "Is there a defined way for managers to raise and escalate concerns about an employee's behaviour, confidentially and without making accusations?" is yes, across everything it should cover. 2. Support for financial pressure: the answer to "Does the organisation offer support to employees in financial difficulty, such as financial wellness or employee assistance programmes?" is yes, across everything it should cover. 3. No conflicting duties when covering: the answer to "Are people in high-risk roles, such as those who can move money or change master data, kept from holding conflicting duties, even temporarily when they cover for colleagues?" is yes, across everything it should cover. 4. High-risk roles identified: A maintained list of high-risk roles covers the whole organisation, including roles that can move money, change master data or manage system access.	STATE 16	HR manager The board or its audit committee	As each case arises, with a monthly review by the process owner	Management's own records show that every case in the period passes this test: Is there a defined way for managers to raise and escalate concerns about an employee's behaviour, confidentially and without making accusations?
CI-FS-D6-01 D6-P-02 30 days	**Stop the scheme where an unauthorised payment leaves the bank.**	1. Capture and authorise separated: Platform roles ensure that no one who captures payments or loads beneficiaries can authorise them.	STATE 17	Financial controller or treasury manager The board or its audit committee	Every payment batch	Management's own records show, for every case in the period: platform roles ensure that no one who captures payments or loads beneficiaries can authorise them.

ID	OBJECTIVE	RECOMMENDED DESIGN	ASSESSED	OVERSIGHT	FREQUENCY	TEST
CI-FS-D7-01 D7-R-01 30 days	**Stop the scheme where refunds are stolen.**	1. Refunds to the original source: Every refund goes to the original payment method or to a customer account verified before payment.	**STATE 18**	Customer service or finance manager The board or its audit committee	As each case arises, with a monthly review by the process owner	Management's own records show, for every case in the period: every refund goes to the original payment method or to a customer account verified before payment.
CI-FS-D8-01 D8-C-03 30 days	**Stop the scheme where cash takings are stolen.**	1. Dual control at hand-overs: Whenever cash changes hands, two people count it, record it and sign for it. 2. Takings checked against an independent record: the answer to "Are takings reconciled to an independent record of activity, such as till rolls, ticket numbers, meter readings or occupancy, and not only to what the cashier records?" is yes, across everything it should cover. 3. Deposits reconciled independently: Every deposit and collection is reconciled to the bank statement by someone who does not handle the cash, using statements obtained directly from the bank.	**STATE 19**	Store, branch or cash office manager The board or its audit committee	Every shift or banking cycle	Management's own records show, for every case in the period: whenever cash changes hands, two people count it, record it and sign for it.
CI-FS-D8-02 D8-K-02 30 days	**Stop the scheme where stock is stolen and hidden in the counts.**	1. How stock is recorded: the answer to "How is stock recorded?" is yes, across everything it should cover. 2. Store access limited: the answer to "Is access to stores and warehouses limited to authorised people, with visitors and contractors recorded?" is yes, across everything it should cover. 3. Issues against approved requests: the answer to "Are stock issues and transfers recorded against an approved requisition or order before goods leave the store?" is yes, across everything it should cover. 4. Differences explained before adjusting: the answer to "Are count differences investigated and explained before the records are adjusted?" is yes, across everything it should cover. 5. High-value items secured: the answer to "Are high-value or easily resold items kept in a secure area with extra controls, such as cages, seals or serial number tracking?" is yes, across everything it should cover. 6. Custody separated from records: At every store, the people who keep stock records are different from those who hold the stock, and system access enforces this.	**STATE 20**	Financial controller The board or its audit committee	Every count cycle	Management's own records show that every case in the period passes this test: How is stock recorded?
CI-FS-D8-11 D8-M-01 90 days	**Stop the scheme where losses are never tracked.**	1. Losses tracked and reported: the answer to "Are losses of cash, stock and assets tracked over time and by location, and reported to management?" is yes, across everything it should cover.	**STATE 21**	Financial controller or internal audit The board or its audit committee	Monthly	Management's own records show that every case in the period passes this test: Are losses of cash, stock and assets tracked over time and by location, and reported to management?

FICTIONAL PROTOTYPE. Staged review answers from a fictional organisation. All figures are test fixtures, not an approved score.

ID	Objective	Recommended design	Assessed	Oversight	Frequency	Test
CI-FS-D9-01 D9-E-01 30 days	**Stop the scheme where an email account is taken over.**	1. Mailbox rules and odd logins alerted: the answer to "Are new forwarding or inbox rules, and logins from unusual locations, alerted and reviewed?" is yes, across everything it should cover.	STATE 22	Head of IT or IT provider The board or its audit committee	Continuous, with monthly review	Management's own records show that every case in the period passes this test: Are new forwarding or inbox rules, and logins from unusual locations, alerted and reviewed?
CI-FS-D10-01 D10-N-01 30 days	**Stop the scheme where concerns are never reported.**	1. Speak-up channel: the answer to "Does the organisation have a speak-up or whistleblowing channel?" is yes, across everything it should cover.	STATE 23	HR manager or owner The board or its audit committee	As each case arises, with a monthly review by the process owner	Management's own records show that every case in the period passes this test: Does the organisation have a speak-up or whistleblowing channel?
CI-FS-D10-02 D10-P-01 30 days	**Stop the scheme where a reporter is exposed or retaliated against.**	1. Retaliation risk assessed: the answer to "When a report is received, is the reporter's risk of retaliation or harm assessed, and are protective steps taken where needed?" is yes, across everything it should cover.	STATE 24	Ethics officer or HR manager The board or its audit committee	As each case arises, with a monthly review by the process owner	Management's own records show that every case in the period passes this test: When a report is received, is the reporter's risk of retaliation or harm assessed, and are protective steps taken where needed?
CI-FS-D10-05 D10-I-04 90 days	**Stop the scheme where an investigation is not independent or fair.**	1. Who investigates: the answer to "Who investigates suspected fraud?" is yes, across everything it should cover.	STATE 25	Head of forensics or investigations The board or its audit committee	Every case	Management's own records show that every case in the period passes this test: Who investigates suspected fraud?

FICTIONAL PROTOTYPE. Staged review answers from a fictional organisation. All figures are test fixtures, not an approved score.

Evidence requirement register

What management should be able to produce for each recommended control. No evidence has been requested, received or examined.

Supplier and payment integrity

CONTROL	EVIDENCE REQUIRED	WHAT IT SHOULD PROVE	MINIMUM ACCEPTABLE CHARACTERISTIC	OWNER / RECENCY
CI-FS-D3-01	**The bribery risk assessment, the list of high-risk activities and the controls applied to them.**	That all high-risk activities, such as winning work, licences, customs and inspections, are identified and have specific extra controls	Covers every case in the period, not a selection	Compliance or legal lead As each case arises, with a monthly review by the process owner
CI-FS-D4-01	**CIPC search results on file, the onboarding form, a sample of supplier records.**	That directors and owners, including those behind holding companies, are identified for every new supplier from an independent source	Covers every case in the period, not a selection	Procurement or creditors manager Every new supplier, customer or employee before activation
CI-FS-D4-05	**Purchase orders or approval records dated before the invoice, for a sample of recent purchases.**	That every purchase is approved by someone with the authority to do so before the organisation commits, and the approval is recorded	Covers every case in the period, not a selection	Procurement manager Every payment run
	Goods received notes, the receiving system, a sample matched to payments.	That receipt is always recorded before the related invoice is paid	Covers every case in the period, not a selection	Stores or operations manager Every payment run
CI-FS-D6-01	**The platform user and role report, the last role review.**	That platform roles ensure that no one who captures payments or loads beneficiaries can authorise them	Covers every case in the period, not a selection	Financial controller or treasury manager Every payment batch

Fraud governance and risk identification

CONTROL	EVIDENCE REQUIRED	WHAT IT SHOULD PROVE	MINIMUM ACCEPTABLE CHARACTERISTIC	OWNER / RECENCY
CI-FS-D2-01	**Minutes of the meeting that accepted the assessment, the register showing risk owners, executive sign-off.**	That management formally accepts the results, and every significant risk has a named owner who has agreed to it	Covers every case in the period, not a selection	Risk manager or fraud risk lead As each case arises, with a monthly review by the process owner
	The fraud risk register, with scheme descriptions for a sample of processes.	That every risk is described as a specific scheme, with the perpetrator, the method and the process it affects	Covers every case in the period, not a selection	Risk manager or fraud risk lead As each case arises, with a monthly review by the process owner

Payroll integrity

CONTROL	EVIDENCE REQUIRED	WHAT IT SHOULD PROVE	MINIMUM ACCEPTABLE CHARACTERISTIC	OWNER / RECENCY
CI-FS-D5-02	**New starter records with the signed appointment and the checker's sign-off.**	That every new record is checked against a signed appointment by someone other than the person who captured it, before the first pay run	Covers every case in the period, not a selection	Payroll manager Every pay run

Identity and access challenge

CONTROL	EVIDENCE REQUIRED	WHAT IT SHOULD PROVE	MINIMUM ACCEPTABLE CHARACTERISTIC	OWNER / RECENCY
CI-FS-D5-12	**The list of high-risk roles and the date it was last reviewed.**	That a maintained list of high-risk roles covers the whole organisation, including roles that can move money, change master data or manage system access	Covers every case in the period, not a selection	HR manager, with the head of IT As each case arises, with a monthly review by the process owner

FICTIONAL PROTOTYPE. Staged review answers from a fictional organisation. All figures are test fixtures, not an approved score.

CONTROL	EVIDENCE REQUIRED	WHAT IT SHOULD PROVE	MINIMUM ACCEPTABLE CHARACTERISTIC	OWNER / RECENCY
CI-FS-D8-02	**Organisation charts for the stores, system access lists for stock records.**	That at every store, the people who keep stock records are different from those who hold the stock, and system access enforces this	Covers every case in the period, not a selection	Warehouse or stores manager Every count cycle

Detection and exception review

CONTROL	EVIDENCE REQUIRED	WHAT IT SHOULD PROVE	MINIMUM ACCEPTABLE CHARACTERISTIC	OWNER / RECENCY
CI-FS-D7-01	**Refund records showing the payment method used, approved exceptions.**	That every refund goes to the original payment method or to a customer account verified before payment	Covers every case in the period, not a selection	Customer service or finance manager As each case arises, with a monthly review by the process owner

Cash custody

CONTROL	EVIDENCE REQUIRED	WHAT IT SHOULD PROVE	MINIMUM ACCEPTABLE CHARACTERISTIC	OWNER / RECENCY
CI-FS-D8-01	**Signed cash count and handover sheets for a sample of days.**	That whenever cash changes hands, two people count it, record it and sign for it	Covers every case in the period, not a selection	Store, branch or cash office manager Every shift or banking cycle
	Deposit reconciliations, bank statements obtained directly, who prepared each reconciliation.	That every deposit and collection is reconciled to the bank statement by someone who does not handle the cash, using statements obtained directly from the bank	Covers every case in the period, not a selection	Store, branch or cash office manager Every shift or banking cycle

FICTIONAL PROTOTYPE. Staged review answers from a fictional organisation. All figures are test fixtures, not an approved score.

12-month action and assurance register

The full twelve-month programme. Not every row is initial implementation: later horizons operate each control through its required cycle and then review whether it is still effective. The work type on each row says which it is.

HORIZON	WORK TYPE	ACTION	OWNER	COMPLETION CRITERION	EFFECTIVENESS MEASURE
30 days	Implement	Confirm with CEO or company secretary how executive accountable for fraud operates and put in place owner has authority across the organisation, dedicated fraud capability and annual fraud action plan.	CEO or company secretary	CEO or company secretary confirms in writing that the controls operate for every case.	Management's own records show that every case in the period passes this test: Does the person who handles fraud risk have the authority and budget to act across the organisation, not only in their own area?
30 days	Implement	Confirm with Risk manager or fraud risk lead how fraud risks assessed operates and put in place management owns the results, process owners take part and processes walked through.	Risk manager or fraud risk lead	Minutes of the meeting that accepted the assessment, the register showing risk owners, executive sign-off. The fraud risk register, with scheme descriptions for a sample of processes.	Management's own records show, for every case in the period: management formally accepts the results, and every significant risk has a named owner who has agreed to it.
30 days	Implement	Confirm with Risk manager or fraud risk lead how AI-enabled fraud covered operates and put in place controls tested against AI fakes, AI methods tested per process and own AI tools in scope.	Risk manager or fraud risk lead	Register entries for AI-enabled schemes, the processes they apply to and the date they were last reviewed.	Management's own records show that every case in the period passes this test: Are controls that rely on recognising a voice, face, signature or document assessed for whether an AI-generated fake could defeat them?
30 days	Implement	Confirm with Compliance or legal lead how bribery prohibited operates and put in place leaders trained on their duties and high-risk activities identified.	Ethics officer or company secretary	The bribery risk assessment, the list of high-risk activities and the controls applied to them. The anti-bribery policy, agent and contractor terms, training records.	Management's own records show that every case in the period passes this test: Are directors and senior managers trained on their personal duties, including reporting corruption under section 34 and the organisation's liability for bribery?
30 days	Implement	Confirm with Procurement or creditors manager how new supplier process operates and put in place new supplier approved by another person, directors compared with staff and dormant suppliers deactivated.	Head of procurement or CFO	CIPC search results on file, the onboarding form, a sample of supplier records. The onboarding procedure, completed onboarding files for a sample of new suppliers, exception reports.	Management's own records show that every case in the period passes this test: Does someone other than the person who captured a new supplier approve it before it becomes active?
30 days	Implement	Confirm with Creditors manager or financial controller how three-way match operates and put in place services confirmed, approved order before commitment and receipt recorded before payment.	Head of procurement or CFO	Purchase orders or approval records dated before the invoice, for a sample of recent purchases. Goods received notes, the receiving system, a sample matched to payments. Payment files showing the order, receipt and invoice, exception reports.	Management's own records show that every case in the period passes this test: For services, does the person receiving the service confirm it was delivered before payment?
30 days	Implement	Confirm with Payroll manager how bank changes confirmed with employee operates and put in place bank change report reviewed.	HR or payroll manager	Bank change records showing how each change was confirmed, the procedure.	Management's own records show that every case in the period passes this test: Is a report of employee bank detail changes reviewed before each pay run?
30 days	Implement	Confirm with Payroll manager or financial controller how payroll reviewed by another person operates and put in place payroll data analysed, new employee checked by another person and independent review of payroll.	HR or payroll manager	New starter records with the signed appointment and the checker's sign-off. Signed payroll review checklists, variance explanations, the approval trail.	Management's own records show that every case in the period passes this test: Does anyone analyse payroll data for unusual patterns?

30 days	Implement	Confirm with Financial controller or treasury manager how two authorisers for every payment operates and put in place capture and authorise separated.	CFO or financial manager	The platform user and role report, the last role review. Platform authorisation settings confirmed by the bank, a sample of released payments.	Management's own records show, for every case in the period: platform roles ensure that no one who captures payments or loads beneficiaries can authorise them.
30 days	Implement	Confirm with Customer service or finance manager how refunds approved independently operates and put in place refunds to the original source.	Commercial or finance manager	Refund records showing the payment method used, approved exceptions. A sample of refunds and credit notes with approvals, system workflow settings.	Management's own records show, for every case in the period: every refund goes to the original payment method or to a customer account verified before payment.
30 days	Implement	Confirm with Store, branch or cash office manager how daily reconciliation operates and put in place dual control at hand-overs, takings checked against an independent record and deposits reconciled independently.	Operations or financial manager	Signed cash count and handover sheets for a sample of days. Deposit reconciliations, bank statements obtained directly, who prepared each reconciliation. Daily reconciliation sheets, the shortages and surpluses log, investigation notes.	Management's own records show, for every case in the period: whenever cash changes hands, two people count it, record it and sign for it.
30 days	Implement	Confirm with Financial controller how independent blind counts operates and put in place how stock is recorded, store access limited and issues against approved requests.	Operations or financial manager	Organisation charts for the stores, system access lists for stock records. Count instructions, count sheets without system quantities, the names of counters and observers.	Management's own records show that every case in the period passes this test: How is stock recorded?
30 days	Implement	Confirm with Head of IT or IT provider how multi-factor on all email operates and put in place mailbox rules and odd logins alerted.	Head of IT or IT provider	The email security report showing multi-factor status for every account, including shared mailboxes.	Management's own records show that every case in the period passes this test: Are new forwarding or inbox rules, and logins from unusual locations, alerted and reviewed?
30 days	Implement	Confirm with HR manager or owner how people know whom to tell operates and put in place speak-up channel.	Head of forensics, risk or compliance	Staff communication on whom to tell, induction material, awareness checks.	Management's own records show that every case in the period passes this test: Does the organisation have a speak-up or whistleblowing channel?
30 days	Implement	Confirm with Ethics officer or HR manager how identities kept confidential operates and put in place retaliation risk assessed.	Head of forensics, risk or compliance	The speak-up policy, the access list for reports, the case system's access log. The policy prohibiting retaliation, the disciplinary code, retaliation cases and outcomes.	Management's own records show that every case in the period passes this test: When a report is received, is the reporter's risk of retaliation or harm assessed, and are protective steps taken where needed?
90 days	Implement	Confirm with Risk manager or fraud risk lead how response decided operates and put in place likelihood and impact rated.	Risk manager or fraud risk lead	Recorded responses for risks above tolerance, acceptance approvals, the action plan.	Management's own records show that every case in the period passes this test: Is each fraud risk rated for how likely it is and how much harm it could cause?
90 days	Implement	Confirm with Risk manager or fraud risk lead how updated when the business changes operates and put in place owners know their risks and assessment documented.	Risk manager or fraud risk lead	Update records linked to business changes, project checklists that include a fraud risk step.	Management's own records show that every case in the period passes this test: Do the people who run each process know the fraud risks recorded for their area?
90 days	Implement	Confirm with HR lead or ethics officer how code accessible to staff operates and put in place written code of conduct, programme independently reviewed and trends reported upward.	Ethics officer or company secretary	HR lead or ethics officer confirms in writing that the controls operate for every case.	Management's own records show that every case in the period passes this test: Does the organisation have a written code of conduct?

90 days	Implement	Close the scheme where donations or sponsorships channel bribes: put in place recipients checked for links.	Ethics officer or company secretary	CSI or sustainability lead confirms in writing that the controls operate for every case.	Management's own records show that every case in the period passes this test: Are recipients checked for links to public officials, customers' decision-makers and employees before money is committed?
90 days	Implement	Close the scheme where procurement anomalies are never noticed: put in place senior review of supplier payments, data reviewed for unusual patterns, split orders monitored and independent review of procurement.	Head of procurement or CFO	Creditors manager or financial controller confirms in writing that the controls operate for every case.	Management's own records show that every case in the period passes this test: Does someone senior review a list of supplier payments at least once a month?
90 days	Implement	Confirm with Procurement or the finance manager how variations approved first operates and put in place contract register, large variations escalated and written supplier contracts.	Head of procurement or CFO	Procurement or the finance manager confirms in writing that the controls operate for every case.	Management's own records show that every case in the period passes this test: Is there a register of all active supplier contracts?
90 days	Implement	Close the scheme where hours and overtime are inflated: put in place hours approved by supervisor.	HR or payroll manager	HR or payroll manager confirms in writing that the controls operate for every case.	Management's own records show that every case in the period passes this test: Are hours approved by a supervisor before they are paid?
90 days	Implement	Confirm with HR manager how block leave required operates and put in place concerns raised fairly, support for financial pressure and no conflicting duties when covering.	HR or payroll manager	The list of high-risk roles and the date it was last reviewed. The leave policy, leave records for sensitive roles, approved exceptions.	Management's own records show that every case in the period passes this test: Is there a defined way for managers to raise and escalate concerns about an employee's behaviour, confidentially and without making accusations?
90 days	Implement	Close the scheme where losses are never tracked: put in place losses tracked and reported.	Operations or financial manager	Financial controller or internal audit confirms in writing that the controls operate for every case.	Management's own records show that every case in the period passes this test: Are losses of cash, stock and assets tracked over time and by location, and reported to management?
90 days	Implement	Confirm with Head of forensics or investigations how investigators independent operates and put in place who investigates.	Head of forensics, risk or compliance	Independence declarations in case files, the investigator assignment record.	Management's own records show that every case in the period passes this test: Who investigates suspected fraud?
3-6 months	Embed & evidence	Retained evidence covering one full operating cycle (Annual review of mandates), with a management sample and any exceptions recorded.	CEO or company secretary	The retained evidence covers the required population for the full cycle and exceptions are resolved or escalated.	Management's own records show that every case in the period passes this test: Does the person who handles fraud risk have the authority and budget to act across the organisation, not only in their own area?
3-6 months	Embed & evidence	Retained evidence covering one full operating cycle (As each case arises, with a monthly review by the process owner), with a management sample and any exceptions recorded.	Risk manager or fraud risk lead	The retained evidence covers the required population for the full cycle and exceptions are resolved or escalated.	Management's own records show, for every case in the period: management formally accepts the results, and every significant risk has a named owner who has agreed to it.
3-6 months	Embed & evidence	Retained evidence covering one full operating cycle (As each case arises, with a monthly review by the process owner), with a management sample and any exceptions recorded.	Risk manager or fraud risk lead	The retained evidence covers the required population for the full cycle and exceptions are resolved or escalated.	Management's own records show that every case in the period passes this test: Are controls that rely on recognising a voice, face, signature or document assessed for whether an AI-generated fake could defeat them?

3-6 months	Embed & evidence	Retained evidence covering one full operating cycle (As each case arises, with a monthly review by the process owner), with a management sample and any exceptions recorded.	Risk manager or fraud risk lead	The retained evidence covers the required population for the full cycle and exceptions are resolved or escalated.	Management's own records show that every case in the period passes this test: Is each fraud risk rated for how likely it is and how much harm it could cause?
3-6 months	Embed & evidence	Retained evidence covering one full operating cycle (As each case arises, with a monthly review by the process owner), with a management sample and any exceptions recorded.	Risk manager or fraud risk lead	The retained evidence covers the required population for the full cycle and exceptions are resolved or escalated.	Management's own records show that every case in the period passes this test: Do the people who run each process know the fraud risks recorded for their area?
3-6 months	Embed & evidence	Retained evidence covering one full operating cycle (As each case arises, with a monthly review by the process owner), with a management sample and any exceptions recorded.	Ethics officer or company secretary	The retained evidence covers the required population for the full cycle and exceptions are resolved or escalated.	Management's own records show that every case in the period passes this test: Are directors and senior managers trained on their personal duties, including reporting corruption under section 34 and the organisation's liability for bribery?
3-6 months	Embed & evidence	Retained evidence covering one full operating cycle (As each case arises, with a monthly review by the process owner), with a management sample and any exceptions recorded.	Ethics officer or company secretary	The retained evidence covers the required population for the full cycle and exceptions are resolved or escalated.	Management's own records show that every case in the period passes this test: Does the organisation have a written code of conduct?
3-6 months	Embed & evidence	Retained evidence covering one full operating cycle (As each case arises, with a monthly review by the process owner), with a management sample and any exceptions recorded.	Ethics officer or company secretary	The retained evidence covers the required population for the full cycle and exceptions are resolved or escalated.	Management's own records show that every case in the period passes this test: Are recipients checked for links to public officials, customers' decision-makers and employees before money is committed?
3-6 months	Embed & evidence	Retained evidence covering one full operating cycle (As each case arises, with a monthly review by the process owner), with a management sample and any exceptions recorded.	Head of procurement or CFO	The retained evidence covers the required population for the full cycle and exceptions are resolved or escalated.	Management's own records show that every case in the period passes this test: Is there a register of all active supplier contracts?
3-6 months	Embed & evidence	Retained evidence covering one full operating cycle (As each case arises, with a monthly review by the process owner), with a management sample and any exceptions recorded.	HR or payroll manager	The retained evidence covers the required population for the full cycle and exceptions are resolved or escalated.	Management's own records show that every case in the period passes this test: Is a report of employee bank detail changes reviewed before each pay run?
3-6 months	Embed & evidence	Retained evidence covering one full operating cycle (As each case arises, with a monthly review by the process owner), with a management sample and any exceptions recorded.	HR or payroll manager	The retained evidence covers the required population for the full cycle and exceptions are resolved or escalated.	Management's own records show that every case in the period passes this test: Are hours approved by a supervisor before they are paid?
3-6 months	Embed & evidence	Retained evidence covering one full operating cycle (As each case arises, with a monthly review by the process owner), with a management sample and any exceptions recorded.	HR or payroll manager	The retained evidence covers the required population for the full cycle and exceptions are resolved or escalated.	Management's own records show that every case in the period passes this test: Is there a defined way for managers to raise and escalate concerns about an employee's behaviour, confidentially and without making accusations?
3-6 months	Embed & evidence	Retained evidence covering one full operating cycle (As each case arises, with a monthly review by the process owner), with a management sample and any exceptions recorded.	Commercial or finance manager	The retained evidence covers the required population for the full cycle and exceptions are resolved or escalated.	Management's own records show, for every case in the period: every refund goes to the original payment method or to a customer account verified before payment.
3-6 months	Embed & evidence	Retained evidence covering one full operating cycle (Monthly), with a management sample and any exceptions recorded.	Operations or financial manager	The retained evidence covers the required population for the full cycle and exceptions are resolved or escalated.	Management's own records show that every case in the period passes this test: Are losses of cash, stock and assets tracked over time and by location, and reported to management?

3-6 months	Embed & evidence	Retained evidence covering one full operating cycle (Continuous, with monthly review), with a management sample and any exceptions recorded.	Head of IT or IT provider	The retained evidence covers the required population for the full cycle and exceptions are resolved or escalated.	Management's own records show that every case in the period passes this test: Are new forwarding or inbox rules, and logins from unusual locations, alerted and reviewed?
3-6 months	Embed & evidence	Retained evidence covering one full operating cycle (As each case arises, with a monthly review by the process owner), with a management sample and any exceptions recorded.	Head of forensics, risk or compliance	The retained evidence covers the required population for the full cycle and exceptions are resolved or escalated.	Management's own records show that every case in the period passes this test: Does the organisation have a speak-up or whistleblowing channel?
3-6 months	Embed & evidence	Retained evidence covering one full operating cycle (As each case arises, with a monthly review by the process owner), with a management sample and any exceptions recorded.	Head of forensics, risk or compliance	The retained evidence covers the required population for the full cycle and exceptions are resolved or escalated.	Management's own records show that every case in the period passes this test: When a report is received, is the reporter's risk of retaliation or harm assessed, and are protective steps taken where needed?
6-12 months	Assure & review	A management or assurance review of CI-FS-D1-01 covering effectiveness, exception trend and dependency, evidenced against: Management's own records show that every case in the period passes this test: Does the person who handles fraud risk have the authority and budget to act across the organisation, not only in their own area?	CEO or company secretary	Management's own records show that every case in the period passes this test: Does the person who handles fraud risk have the authority and budget to act across the organisation, not only in their own area?	Management's own records show that every case in the period passes this test: Does the person who handles fraud risk have the authority and budget to act across the organisation, not only in their own area?
6-12 months	Assure & review	A management or assurance review of CI-FS-D2-01 covering effectiveness, exception trend and dependency, evidenced against: Management's own records show, for every case in the period: management formally accepts the results, and every significant risk has a named owner who has agreed to it.	Risk manager or fraud risk lead	Management's own records show, for every case in the period: management formally accepts the results, and every significant risk has a named owner who has agreed to it.	Management's own records show, for every case in the period: management formally accepts the results, and every significant risk has a named owner who has agreed to it.
6-12 months	Assure & review	A management or assurance review of CI-FS-D2-02 covering effectiveness, exception trend and dependency, evidenced against: Management's own records show that every case in the period passes this test: Are controls that rely on recognising a voice, face, signature or document assessed for whether an AI-generated fake could defeat them?	Risk manager or fraud risk lead	Management's own records show that every case in the period passes this test: Are controls that rely on recognising a voice, face, signature or document assessed for whether an AI-generated fake could defeat them?	Management's own records show that every case in the period passes this test: Are controls that rely on recognising a voice, face, signature or document assessed for whether an AI-generated fake could defeat them?
6-12 months	Assure & review	A management or assurance review of CI-FS-D2-05 covering effectiveness, exception trend and dependency, evidenced against: Management's own records show that every case in the period passes this test: Is each fraud risk rated for how likely it is and how much harm it could cause?	Risk manager or fraud risk lead	Management's own records show that every case in the period passes this test: Is each fraud risk rated for how likely it is and how much harm it could cause?	Management's own records show that every case in the period passes this test: Is each fraud risk rated for how likely it is and how much harm it could cause?
6-12 months	Assure & review	A management or assurance review of CI-FS-D2-06 covering effectiveness, exception trend and dependency, evidenced against: Management's own records show that every case in the period passes this test: Do the people who run each process know the fraud risks recorded for their area?	Risk manager or fraud risk lead	Management's own records show that every case in the period passes this test: Do the people who run each process know the fraud risks recorded for their area?	Management's own records show that every case in the period passes this test: Do the people who run each process know the fraud risks recorded for their area?

6-12 months	Assure & review	A management or assurance review of CI-FS-D3-01 covering effectiveness, exception trend and dependency, evidenced against: Management's own records show that every case in the period passes this test: Are directors and senior managers trained on their personal duties, including reporting corruption under section 34 and the organisation's liability for bribery?	Ethics officer or company secretary	Management's own records show that every case in the period passes this test: Are directors and senior managers trained on their personal duties, including reporting corruption under section 34 and the organisation's liability for bribery?	Management's own records show that every case in the period passes this test: Are directors and senior managers trained on their personal duties, including reporting corruption under section 34 and the organisation's liability for bribery?
6-12 months	Assure & review	A management or assurance review of CI-FS-D3-10 covering effectiveness, exception trend and dependency, evidenced against: Management's own records show that every case in the period passes this test: Does the organisation have a written code of conduct?	Ethics officer or company secretary	Management's own records show that every case in the period passes this test: Does the organisation have a written code of conduct?	Management's own records show that every case in the period passes this test: Does the organisation have a written code of conduct?
6-12 months	Assure & review	A management or assurance review of CI-FS-D3-11 covering effectiveness, exception trend and dependency, evidenced against: Management's own records show that every case in the period passes this test: Are recipients checked for links to public officials, customers' decision-makers and employees before money is committed?	Ethics officer or company secretary	Management's own records show that every case in the period passes this test: Are recipients checked for links to public officials, customers' decision-makers and employees before money is committed?	Management's own records show that every case in the period passes this test: Are recipients checked for links to public officials, customers' decision-makers and employees before money is committed?
6-12 months	Assure & review	A management or assurance review of CI-FS-D4-13 covering effectiveness, exception trend and dependency, evidenced against: Management's own records show that every case in the period passes this test: Is there a register of all active supplier contracts?	Head of procurement or CFO	Management's own records show that every case in the period passes this test: Is there a register of all active supplier contracts?	Management's own records show that every case in the period passes this test: Is there a register of all active supplier contracts?
6-12 months	Assure & review	A management or assurance review of CI-FS-D5-01 covering effectiveness, exception trend and dependency, evidenced against: Management's own records show that every case in the period passes this test: Is a report of employee bank detail changes reviewed before each pay run?	HR or payroll manager	Management's own records show that every case in the period passes this test: Is a report of employee bank detail changes reviewed before each pay run?	Management's own records show that every case in the period passes this test: Is a report of employee bank detail changes reviewed before each pay run?
6-12 months	Assure & review	A management or assurance review of CI-FS-D5-09 covering effectiveness, exception trend and dependency, evidenced against: Management's own records show that every case in the period passes this test: Are hours approved by a supervisor before they are paid?	HR or payroll manager	Management's own records show that every case in the period passes this test: Are hours approved by a supervisor before they are paid?	Management's own records show that every case in the period passes this test: Are hours approved by a supervisor before they are paid?
6-12 months	Assure & review	A management or assurance review of CI-FS-D5-12 covering effectiveness, exception trend and dependency, evidenced against: Management's own records show that every case in the period passes this test: Is there a defined way for managers to raise and escalate concerns about an employee's behaviour, confidentially and without making accusations?	HR or payroll manager	Management's own records show that every case in the period passes this test: Is there a defined way for managers to raise and escalate concerns about an employee's behaviour, confidentially and without making accusations?	Management's own records show that every case in the period passes this test: Is there a defined way for managers to raise and escalate concerns about an employee's behaviour, confidentially and without making accusations?
6-12 months	Assure & review	A management or assurance review of CI-FS-D7-01 covering effectiveness, exception trend and dependency, evidenced against: Management's own records show, for every case in the period: every refund goes to the original payment method or to a customer account verified before payment.	Commercial or finance manager	Management's own records show, for every case in the period: every refund goes to the original payment method or to a customer account verified before payment.	Management's own records show, for every case in the period: every refund goes to the original payment method or to a customer account verified before payment.

6-12 months	Assure & review	A management or assurance review of CI-FS-D8-11 covering effectiveness, exception trend and dependency, evidenced against: Management's own records show that every case in the period passes this test: Are losses of cash, stock and assets tracked over time and by location, and reported to management?	Operations or financial manager	Management's own records show that every case in the period passes this test: Are losses of cash, stock and assets tracked over time and by location, and reported to management?	Management's own records show that every case in the period passes this test: Are losses of cash, stock and assets tracked over time and by location, and reported to management?
6-12 months	Assure & review	A management or assurance review of CI-FS-D9-01 covering effectiveness, exception trend and dependency, evidenced against: Management's own records show that every case in the period passes this test: Are new forwarding or inbox rules, and logins from unusual locations, alerted and reviewed?	Head of IT or IT provider	Management's own records show that every case in the period passes this test: Are new forwarding or inbox rules, and logins from unusual locations, alerted and reviewed?	Management's own records show that every case in the period passes this test: Are new forwarding or inbox rules, and logins from unusual locations, alerted and reviewed?
6-12 months	Assure & review	A management or assurance review of CI-FS-D10-01 covering effectiveness, exception trend and dependency, evidenced against: Management's own records show that every case in the period passes this test: Does the organisation have a speak-up or whistleblowing channel?	Head of forensics, risk or compliance	Management's own records show that every case in the period passes this test: Does the organisation have a speak-up or whistleblowing channel?	Management's own records show that every case in the period passes this test: Does the organisation have a speak-up or whistleblowing channel?
6-12 months	Assure & review	A management or assurance review of CI-FS-D10-02 covering effectiveness, exception trend and dependency, evidenced against: Management's own records show that every case in the period passes this test: When a report is received, is the reporter's risk of retaliation or harm assessed, and are protective steps taken where needed?	Head of forensics, risk or compliance	Management's own records show that every case in the period passes this test: When a report is received, is the reporter's risk of retaliation or harm assessed, and are protective steps taken where needed?	Management's own records show that every case in the period passes this test: When a report is received, is the reporter's risk of retaliation or harm assessed, and are protective steps taken where needed?

FICTIONAL PROTOTYPE. Staged review answers from a fictional organisation. All figures are test fixtures, not an approved score.

Measurement register

The effectiveness test behind each recommended control, grouped by programme. These are the signals management should expect once the control operates.

Supplier and payment integrity

MEASURE	CONTROLS IT COVERS
Management's own records show that every case in the period passes this test: Are directors and senior managers trained on their personal duties, including reporting corruption under section 34 and the organisation's liability for bribery?	CI-FS-D3-01
Management's own records show that every case in the period passes this test: Are recipients checked for links to public officials, customers' decision-makers and employees before money is committed?	CI-FS-D3-11
Management's own records show that every case in the period passes this test: Does someone other than the person who captured a new supplier approve it before it becomes active?	CI-FS-D4-01
Management's own records show that every case in the period passes this test: For services, does the person receiving the service confirm it was delivered before payment?	CI-FS-D4-05
Management's own records show that every case in the period passes this test: Does someone senior review a list of supplier payments at least once a month?	CI-FS-D4-12
Management's own records show that every case in the period passes this test: Is there a register of all active supplier contracts?	CI-FS-D4-13
Management's own records show, for every case in the period: platform roles ensure that no one who captures payments or loads beneficiaries can authorise them.	CI-FS-D6-01

Fraud governance and risk identification

MEASURE	CONTROLS IT COVERS
Management's own records show that every case in the period passes this test: Does the person who handles fraud risk have the authority and budget to act across the organisation, not only in their own area?	CI-FS-D1-01
Management's own records show, for every case in the period: management formally accepts the results, and every significant risk has a named owner who has agreed to it.	CI-FS-D2-01
Management's own records show that every case in the period passes this test: Are controls that rely on recognising a voice, face, signature or document assessed for whether an AI-generated fake could defeat them?	CI-FS-D2-02
Management's own records show that every case in the period passes this test: Is each fraud risk rated for how likely it is and how much harm it could cause?	CI-FS-D2-05
Management's own records show that every case in the period passes this test: Do the people who run each process know the fraud risks recorded for their area?	CI-FS-D2-06

Payroll integrity

MEASURE	CONTROLS IT COVERS
Management's own records show that every case in the period passes this test: Is a report of employee bank detail changes reviewed before each pay run?	CI-FS-D5-01
Management's own records show that every case in the period passes this test: Does anyone analyse payroll data for unusual patterns?	CI-FS-D5-02
Management's own records show that every case in the period passes this test: Are hours approved by a supervisor before they are paid?	CI-FS-D5-09

Incident response and evidence integrity

MEASURE	CONTROLS IT COVERS
Management's own records show that every case in the period passes this test: Does the organisation have a speak-up or whistleblowing channel?	CI-FS-D10-01
Management's own records show that every case in the period passes this test: When a report is received, is the reporter's risk of retaliation or harm assessed, and are protective steps taken where needed?	CI-FS-D10-02
Management's own records show that every case in the period passes this test: Who investigates suspected fraud?	CI-FS-D10-05

FICTIONAL PROTOTYPE. Staged review answers from a fictional organisation. All figures are test fixtures, not an approved score.

MEASURE	CONTROLS IT COVERS
Management's own records show that every case in the period passes this test: Is there a defined way for managers to raise and escalate concerns about an employee's behaviour, confidentially and without making accusations?	CI-FS-D5-12
Management's own records show that every case in the period passes this test: Are new forwarding or inbox rules, and logins from unusual locations, alerted and reviewed?	CI-FS-D9-01

Stock and asset custody

MEASURE	CONTROLS IT COVERS
Management's own records show that every case in the period passes this test: How is stock recorded?	CI-FS-D8-02
Management's own records show that every case in the period passes this test: Are losses of cash, stock and assets tracked over time and by location, and reported to management?	CI-FS-D8-11

Culture and continuous improvement

MEASURE	CONTROLS IT COVERS
Management's own records show that every case in the period passes this test: Does the organisation have a written code of conduct?	CI-FS-D3-10

Detection and exception review

MEASURE	CONTROLS IT COVERS
Management's own records show, for every case in the period: every refund goes to the original payment method or to a customer account verified before payment.	CI-FS-D7-01

Cash custody

MEASURE	CONTROLS IT COVERS
Management's own records show, for every case in the period: whenever cash changes hands, two people count it, record it and sign for it.	CI-FS-D8-01